

PIEDPIN

Let's try CISSP!

なぜCISSPを学ぶのか

- ✓ CISSP(Certified Information Systems Security Professional)とは、世界標準の**セキュリティ・プロフェッショナル認定**です。
- ✓ (ISC)²（国際情報システムセキュリティ認証コンソーシアム、International Information Systems Security Certification Consortium）が認定を行っています。
- ✓ 情報セキュリティ専門家が共通言語として利用している『(ISC)² CISSP CBK』を理解している者に与えられる資格です。
- ✓ 2004年6月に、米国規格協会（ANSI）より**ISO/IEC17024**の認証を受け、信頼度がより高くなりました。（https://japan.isc2.org/cissp_about.html）
- ✓ 2022年7月1日現在、日本のCISSPは**3,699**人です。

(ISC)² が展開する資格ソリューション



国際的に認められた情報セキュリティ・プロフェッショナル認定資格です。米国規格協会（ANSI）よりISO/IEC17024の認証を受けた。



ベンダーフリー・カントリーフリーの情報セキュリティの資格です。情報セキュリティに従事しないが、組織を理解し、適切なコミュニケーションを行う。



クラウドサービスを安全に利用するために必要な知識を体系化した資格です。



ソフトウェアの脆弱性に端を発したセキュリティインシデントの増加や、政府や重要インフラにおけるセキュアなソフトウェアニーズに対応する資格です。

(ISC)² CISSP CBK ドメイン



ドメイン 1
セキュリティとリスク
マネジメント



ドメイン 2
資産のセキュリティ



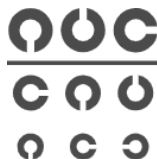
ドメイン 3
セキュリティアーキ
テクチャとエンジニ
アリング



ドメイン 4
通信とネットワー
クのセキュリティ



ドメイン 5
アイデンティティと
アクセスの管理



ドメイン 6
セキュリティの評
価とテスト



ドメイン 7
セキュリティの運用



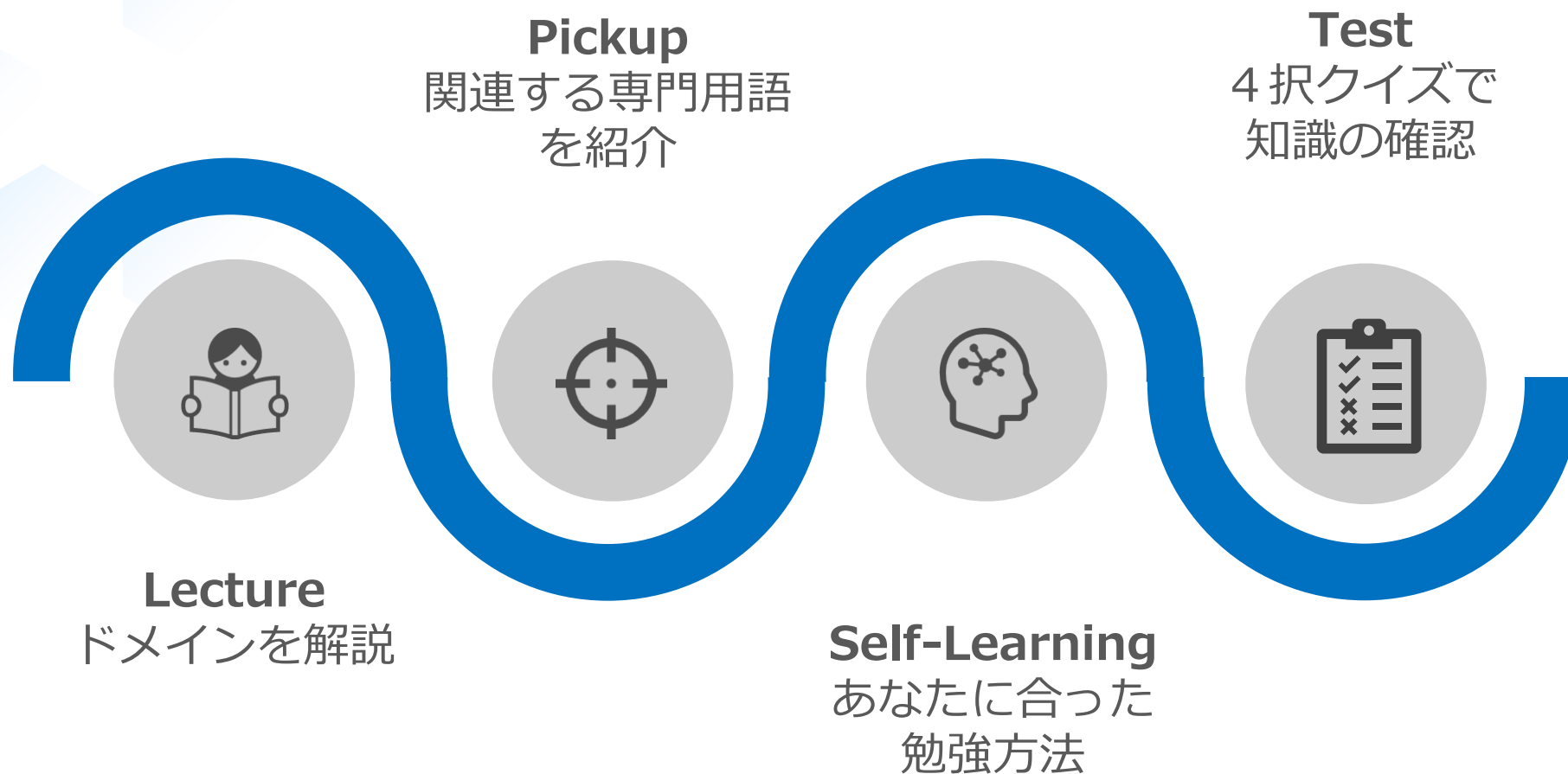
ドメイン 8
ソフトウェア開発
セキュリティ

あなたのゴールと本レッスンの内容

- ✓ 情報セキュリティ初心者のために設計されたCISSP講座
経験者からすると“当たり前”と感じる内容も含まれます。
- ✓ 本レッスンの対象は、CBKのドメイン 7 です。
他のドメインのレッスンは対象外となります。
- ✓ CISSP合格のためのアップグレードが必要です。
現代のセキュリティの関心、流行、考え方を織り込みます。



レッスンの流れ



ドメイン別試験比重



ドメイン 1
セキュリティと
リスクマネジメント

16%



ドメイン 2
資産のセキュリティ

10%



ドメイン 3
セキュリティアーキテク
チャとエンジニアリング

13%



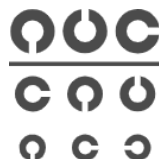
ドメイン 4
通信とネットワーク
のセキュリティ

13%



ドメイン 5
アイデンティティと
アクセスの管理

13%



ドメイン 6
セキュリティの評価
とテスト

12%



ドメイン 7
セキュリティの運用

13%



ドメイン 8
ソフトウェア開発
セキュリティ

10%



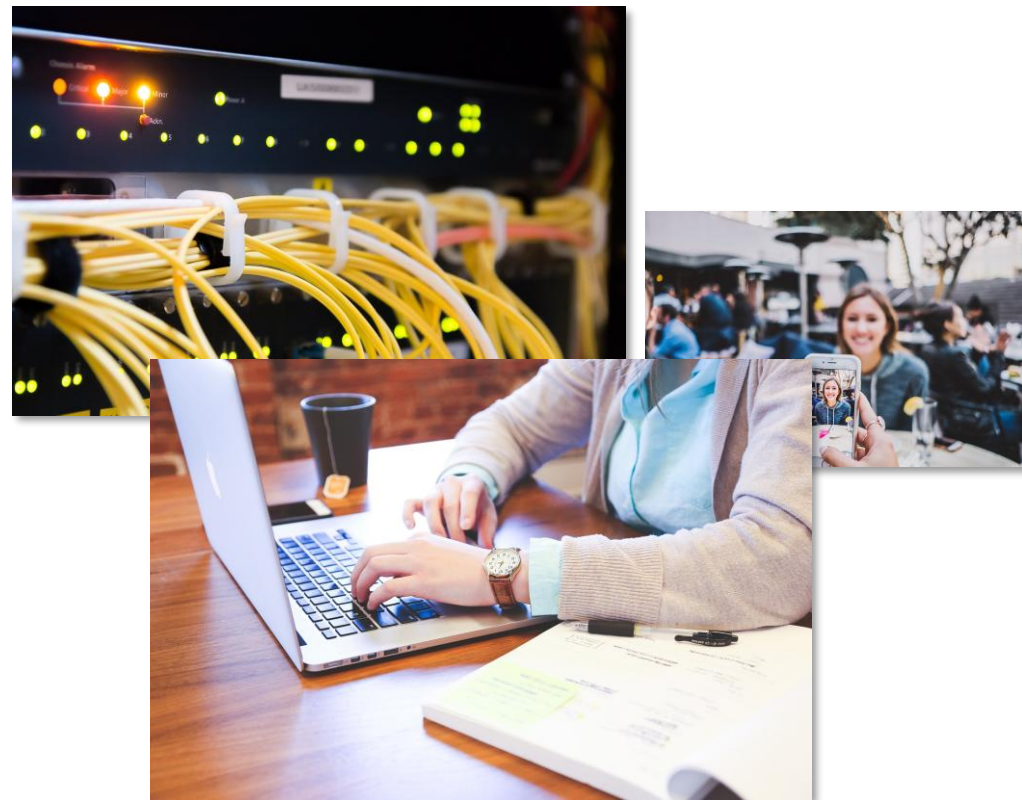
デジタルフォレンジック

デジタルフォレンジック

調査の目的と手順

● デジタルフォレンジックとは

- デジタルフォレンジックとは、コンピュータ犯罪の解決に向け、デジタルデバイスから発見されたデータの証拠の適切な収集と保護です。
- ほとんどの電子記憶媒体がデジタルフォレンジックの調査対象です。
- Artifactとは、コンピュータやデジタルデバイス上で発見されるデータや情報の断片で、特定のユーザーアクションやシステムの動作の痕跡を示すものを指します。
- 機密情報が漏洩した場合には、持ち出された経路、情報漏洩の範囲、持ち出したのか人物の特定するなど、捜査もしくは裁判に必要な情報を情報技術を用いて明らかにします。

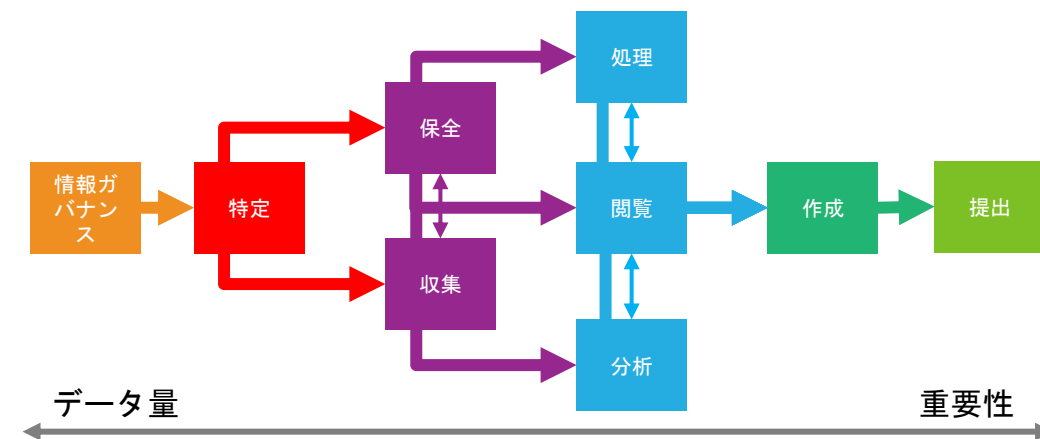


デジタルフォレンジック

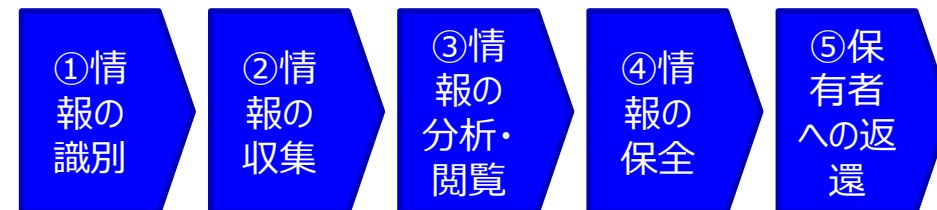
調査の目的と手順

● e-Discovery（電子証拠開示）

- e-Discoveryとは、法的手続き、訴訟、政府の調査、または情報公開法の要請において、電子形式の情報を開示する手続きのことです。
- 紙の文章と電子文書は、その無形の形態、量、一過性、永続性のために異なると考えられています。
- 電子文書には、紙の文書にはないメタデータが添付されており、証拠として重要な役割を果たすことがあります。
- 電子文書のメタデータを保存するには、証拠隠滅を防ぐための特別な課題があります。
- e-Discoveryの対象となる電子データは、Office文書、電子メールにいたるまであらゆるデータが含まれるため、データの保管だけで膨大な量になります。



e-Discoveryプロセス



e-Discoveryの開示プロセス

デジタルフォレンジック

調査の目的と手順

● フォレンジック調査の手順

データの収集

- 攻撃者は、証拠となるようなログを削除して痕跡が残らないように工夫します。
- フォレンジックデータは通常、揮発性の高いものから揮発性の低いものへと作業を進め、RAMから始めてハードディスクで終わらせます。
- 証拠の完全性を疑われないようにすることが重要です。フォレンジックはオリジナルではなくコピーに対して行われますが、フォレンジックの前と後にオリジナルとコピーの両方のハッシュが等しいことを確認します。



収集

- 証拠の確保
- メディアのコピー

ディスクに対しては物理コピーを行います。その際、コピー元とコピー先に対してデジタル署名を取り、同一性を担保します。



検査

- 解析用データへの変換

暗号化データを復号するなど解析用データ形式に変換します。



分析

- 正確な情報の分類

ファイルデータの分類、データファイルの解析を実施する。



報告

- 調査結果の整理
- 正当な調査の証明

法廷などにおいて必要となるレポートを作成する。事実を簡潔に記載する。

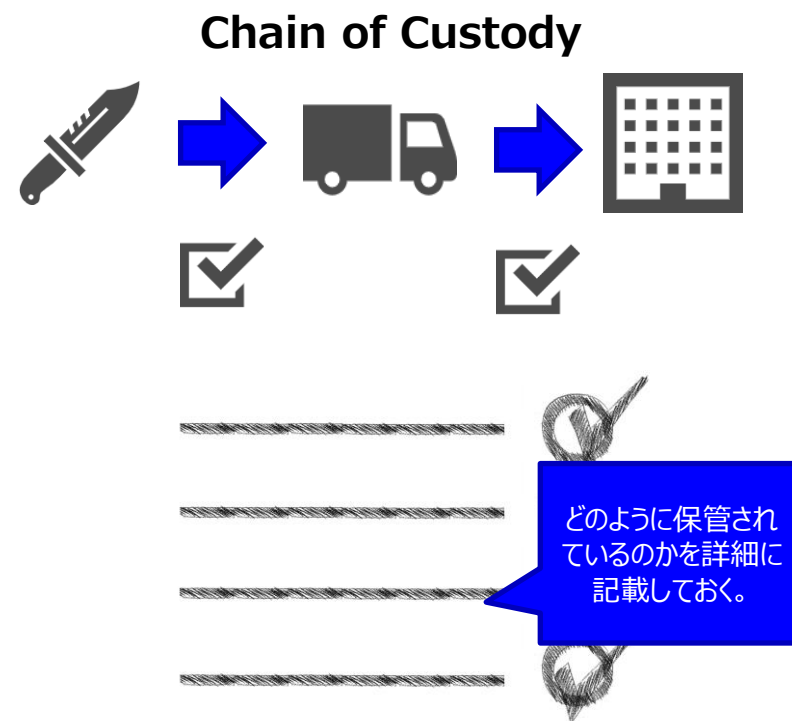
デジタルフォレンジック

調査の目的と手順

● フォレンジック調査の手順

データの保全

- 証拠保全（Chain of Custody）とは、証拠としてみなされ続けるように安全に保管するために、誰がいつそれを持っていたのか？何が行われたのか？いつ行われたのか？を文書化する事です。



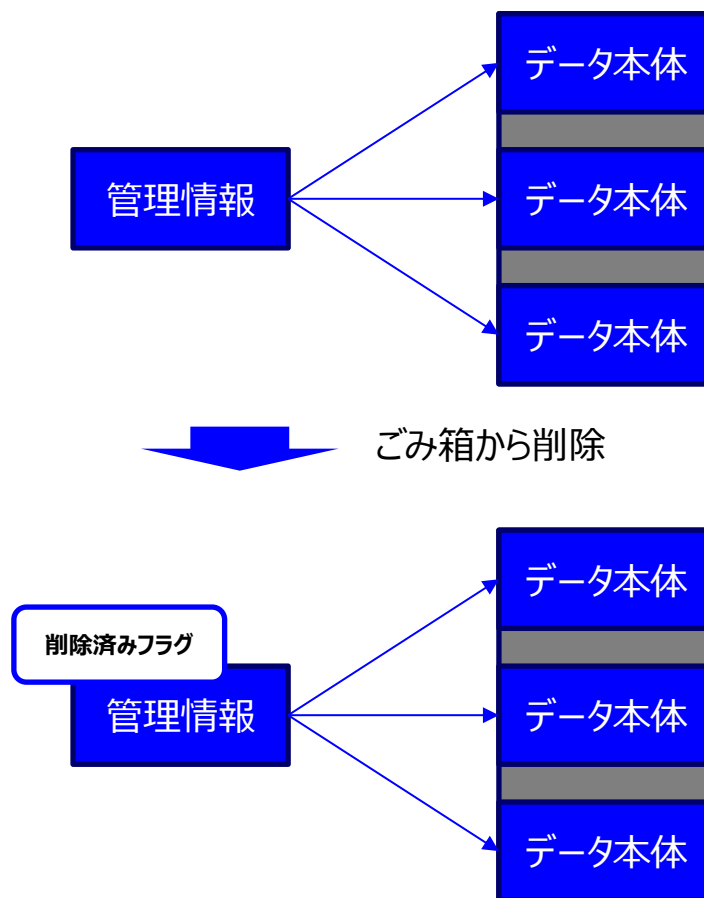
デジタルフォレンジック

調査技術

● ディスク・フォレンジック

ごみ箱を空にしても安全ではない

- コンピュータ上のファイルは、連続した位置に保管されているわけではなく、物理的には断片化されディスクの各所に保管されています。あなたがファイルを開いた際には、まずデータの所在を示した管理情報を確認して、HDD上のデータを拾い集めてきて、一つのまとまったファイルデータに見せています。
- あなたがデスクトップの「ごみ箱」に入れて削除したときには、この管理情報が“再利用可能な状態”にしかたけです。つまりは、再利用可能であるが、まだ実際再利用されていない管理情報があれば、ごみ箱から削除されていようと復元ができます。



デジタルフォレンジック

調査技術

● ディスク・フォレンジック

ディスクパーティション

- 文章ファイルやログなどのデータを物理的に記録する場所はディスクです。
- ディスクを追加するということは、ディスクのどの程度のデータ区域をどのファイル群（ドライブ）を割り当ててるのかを決めています。
- 例えば、アプリログが異常に書き込まれ、OSやアプリ本体が動かなくなるとは困まります。OS用、アプリ用、アプリログ用として利用できるデータ容量を区切っていけば安心です。

割り当てられた領域（Allocated space）

- 割り当てられた領域とは、ディスクの中でデータが存在するとマークされている部分です。

未割り当て領域（Unallocated space）

- 未割り当て領域とは、ディスクの中でアクティブなデータが含まれていないディスクの部分です。

デジタルフォレンジック

調査技術

● ディスク・フォレンジック

スラックスペース

- スラックスペースとは、クラスターと利用しているデータの間の余剰スペースです。
- データは、クラスターと呼ばれる特定のサイズの塊で保存されます。そのため、クラスターの一部の情報を使わなくなったからといって、その分が解放されるわけではありません。
- スラックスペースには、古いデータが含まれていたり、攻撃者が情報を隠すために使用されることがあります。

不良セクター/クラスター/ブロック

- 不良セクターとは、ディスクの中で物理的な欠陥のために読めないスペースです。
- ディスクの一部が物理的な破損などにより読み取れない場合、そのセクタは“不良”としてマークします。
- “不良”とマークされたセクターはデータが読み取れないため、オペレーティングシステムによって無視されます。
- 攻撃者は、セクターなどを“不良”とマークして、ディスクのこの部分にデータを隠すことができます。

デジタルフォレンジック

調査技術

● ディスク・フォレンジック

データカービング

- ファイルデータの固有のビット配列を頼りに、HDDからファイルデータを復元する方法です。
- 管理情報が上書きされてしまった場合には、HDDのどこにデータがあるかわからなくなります。しかし、画像データなどのファイル形式ごとに先頭のビット列は固有であるものがあります。この固有のビット列を検索し、そこから連続しているデータを確認すれば、ファイルデータを管理情報なく復元できます。
- ただし、ファイルデータはディスクに保存される際には断片化されていますから、一部分だけ復元できることを期待します。

SSDではデータ復元が難しい

磁気ディスク（HDD）と半導体メモリ（SSD）のフォレンジックの観点での違いがあります。HDDではディスクのデータがある場所に新しいデータを上書きできますが、SSDではできません。HDDでは新しいデータが利用するまでデータを残留している可能性があります。SSDでは削除されたタイミングで元のデータを消去する必要があり、データの復元力がありません。HDDでは削除前のデータが残っていることがありますが、SSDでは復元はより難しくなります。

デジタルフォレンジック

調査技術

● メモリ・フォレンジック

- メモリ・フォレンジックとは、メインメモリ上のデータをダンプなどの行った後、解析する手順や技術です。
- 具体的には、攻撃者はマルウェアを揮発性メモリに配置するようにし、電源を切るとマルウェアが消すことで証拠を残らないようにします。そのため、攻撃を受けた時には早期にシャットダウンするのではなく、起動し続けても安全と思われる場合は、ネットワークから切断してメモリデータを起動状態を維持しながらコピーしていきます。

試験のテクニック

実際の現場では、メモリからダンプする作業はとても繊細です。そのため、常にメモリをダンプできるわけではありません。
ただ、CISSPの試験では、メモリはダンプでき、フォレンジックデータとして活用できるという前提で問題ありません。

デジタルフォレンジック

調査技術

● ネットワーク・フォレンジック

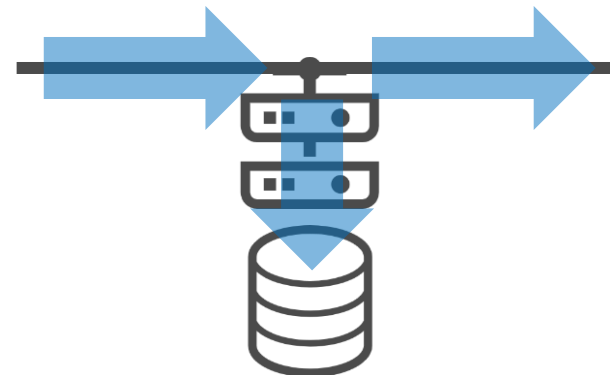
- ネットワークに異常なトラフィックがないかを監視し、侵入者を特定します。
- キャプチャしたネットワークトラフィックの分析には、転送されたファイルの再構成、キーワードの検索、電子メールやチャットセッションなどのコミュニケーションの解析などの作業が含まれます。

Catch it as you can (できる限りキャッチ)

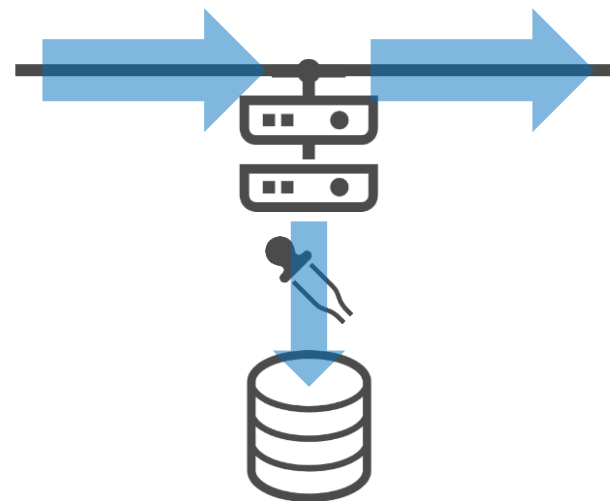
- ネットワークトラフィックの収集の一つであり、特定のトラフィックポイントを通過するすべてのパケットをキャプチャしてストレージに書き込み、その後バッチモードで解析を行うことです。
- すべてのリクエストを保管するほどの大容量のストレージが必要になります。

Stop, look and listen (止めて、見て、聞く)

- ネットワークトラフィックの収集の一つであり、各パケットはメモリ上で基本的な方法で解析され、特定の情報のみが将来の解析のために保存される方法です。
- 各トラフィックを分析していくために、より高速な処理性能が必要となります。



Catch it as you can



Stop, look and listen

デジタルフォレンジック

調査技術

●モバイル・フォレンジック

- 携帯端末やスマートフォンのような無線を用いて通信する機器に対するデジタルフォレンジックです。
- 昨今では、IoT（Internet Of Things）がセキュリティ上の懸念材料になり得ます。すべてのデバイスには豊富な情報が詰まっています。
- GPSは、車、電話、人がある時間にどこにいたかを示していますし、エアコンの電源が入っているか時間情報は、その時間に誰かが家にいたかを推定することができます。
- フォレンジック調査員は、調査において、組み込みデバイスにアクセスし、解釈し、分析する能力が必要になってくるでしょう。

●ソフトウェア・フォレンジック

- ソフトウェアのフォレンジック解析は、ソフトウェアの比較やリバースエンジニアリングを行うことです。
- フォレンジック調査員は、マルウェアプログラムのバイナリコピーを入手し、何をしているのかを推測しようとしています。

試験のテクニック

リバースエンジニアリングは、ソフトウェアの解析です。つまり、ソフトウェア・フォレンジックは知的財産権の侵害を指すこともあるのでは？と思ったかもしれませんが、ただ、試験の中では悪意の前提がない限りは、正義のデジタルフォレンジックのために実施しているものと判断してよいでしょう。



インシデント管理

インシデント管理

インシデント分類

● インシデント イベント

- ・ イベントとは、観察可能な状態の変化を指します。これはネガティブでもポジティブでもなく、ただ何かが変化したということです。
- ・ 例えば、システムの電源投入、あるセグメントから別のセグメントへのトラフィック、アプリケーションの起動などです。

警告

- ・ 通常の状態ではないことを示し、インシデントにつながる可能性を事前に通知します。
- ・ 特定のイベントが発生した場合に警告を発します。「トラフィック使用率が75%以上、メモリ使用率が90%以上の状態が2分以上続いた場合」などが該当します。

試験のテクニック

インシデントは本来は資産への障害を示す広範囲を示す言葉ですが、試験の中ではインシデントという場合、コンピュータ資産、ネットワーク、情報システムなどのシステムインシデントを指していると考えてよいでしょう。地震やヒューマンエラーまで加味すると考えることが多くなって、必要以上に体力を使ってしまうですよ。

インシデント管理

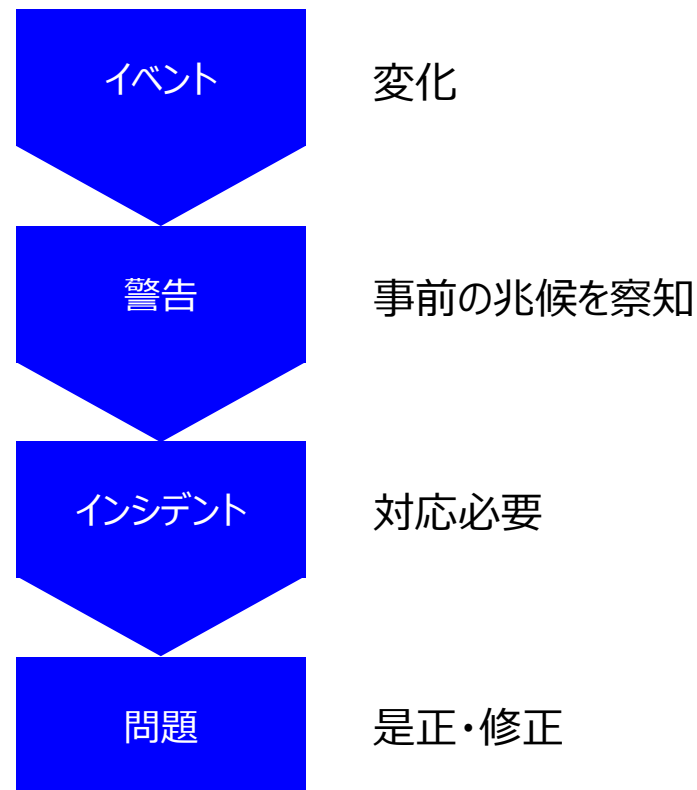
インシデント分類

● インシデント

- ・ インシデントとは、機密性・完全性・可用性に関わる悪影響を及ぼす事象です。
- ・ より一般には、予定していないITサービスの中断、またはITサービス品質の劣化を指します。
- ・ システム上のイベントを監視・検知し、それらのイベントにどのように対応するかをインシデント管理が必要です。
- ・ インシデント対応では、スタッフが何をすべきかを正確に把握し、継続的なトレーニングを受け、手順を理解していることが重要です。

問題

- ・ 問題とは、原因不明のインシデントであり、インシデント対応と同様のステップを踏むことになります。
- ・ 根本原因分析にはより多くの時間が費やされ、何が起こったのかを知ることによって二度と起こらないようにする必要があります。



インシデント管理

インシデント分類

● インシデントの分類

インシデントの影響規模

- 無災害（ Non-Disaster ）とは、非破壊的な障害、ハードディスクの故障、クラスター内の1つのサーバーがダウンなどです。
- 緊急（ Emergency ）とは、緊急を要する人命や財産を失う可能性のある事象です。
- 災害（ Disaster ）とは、当社の施設全体が24時間以上使用できない状態です。
- 大惨事（ Catastrophe ）とは、施設が破壊された状態です。

インシデント管理

インシデント対応

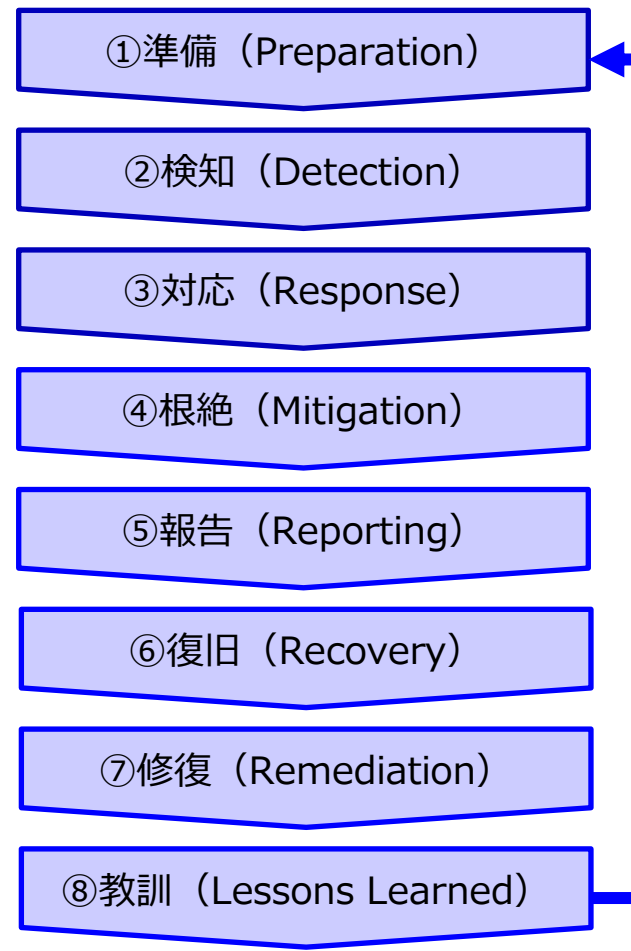
● インシデント対応のプロセス

① 準備 (Preparation)

- ・ インシデントに備えるために行うステップです。
- ・ ポリシーや手順を作成、検知ソフトやハードウェアを調達など、インシデント対応チームに必要なツールを提供します。

他の教材で見たインシデント対応プロセスと異なるようだ

教材によってインシデント対応のプロセスは異なるでしょう。ITILベースのインシデント対応では、イベント管理→インシデント管理→問題管理というより大きなくりで表現されますし、ICS（Incident Command System）ベースのインシデント対応では、トリアージ→緩和→解決→フォローアップというくりになります。ここでは、ほかのフレームを提示された場合であっても概要がわかるように、本講座では最も細かいレベルで説明いたします。



インシデント管理

インシデント対応

● インシデント対応のプロセス

② 検知 (Detection)

- イベントを分析して、それがセキュリティインシデントであるかどうかを判断します。
- イベントを早期に検知すればするほど、早期に対応・解決することができます。
- IDS (Intrusion Detection System) による検知と、IPS (Intrusion Prevention System) による検知とさらなる侵害の防止を行います。
- 初動のタイミングで確認すべきポイントがあります。どのサービスのエラー画面か、いつから発生しているか、現在も続いているか、どのような操作をしたのか、過去にも事象があるか、特定のユーザーにのみ発生するのかなどを聞き出しておくといでしょう。

聞き出すポイント (例)	理由
どのサービスの画面か？	問題箇所の特定、どのシステム担当に連絡するべきかの判断。
いつから発生しているか？	特定時刻のログを取得する必要があります。
現在も続いているか？	ユーザー影響、通知するべきかを確定させる。
どのような操作をしたのか？	原因調査のため、具体的に発生させる手順を確認する。
過去にも事象があるか？	既知の問題であれば、現在原因調査をする必要がありません。
特定のユーザーにのみ発生するのか？	ユーザー環境によるものか、システムによるものかを切り分けることができます。

① 準備 (Preparation)

② 検知 (Detection)

③ 対応 (Response)

④ 根絶 (Mitigation)

⑤ 報告 (Reporting)

⑥ 復旧 (Recovery)

⑦ 修復 (Remediation)

⑧ 教訓 (Lessons Learned)

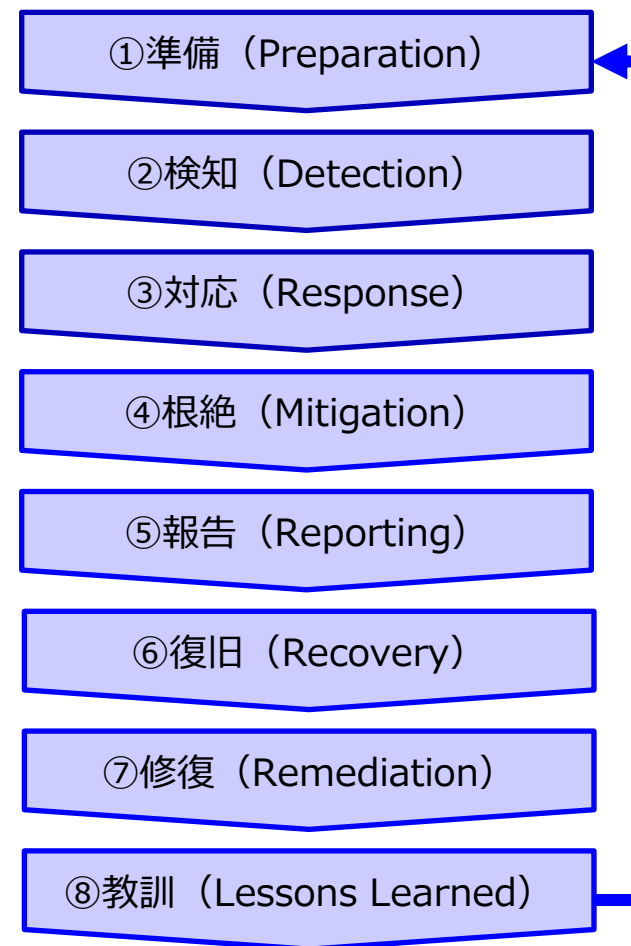
インシデント管理

インシデント対応

● インシデント対応のプロセス

③ 対応 (Response)

- インシデント対応チームが影響を受けたシステムを調査し、インシデントの結果としてさらなる被害が発生しないようにします。
- システムをネットワークから切り離す、トラフィックを隔離する、システムの電源を切るなど、インシデントの範囲と深刻さの両方を最小限に抑えるために、計画に基づいてシステムを隔離します。



インシデント管理

インシデント対応

●インシデント対応のプロセス

④根絶（Mitigation）

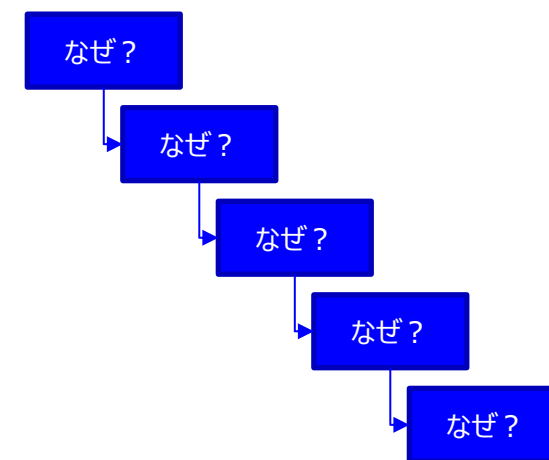
- ・ インシデントの原因を理解し、後の復旧段階でシステムを確実にクリーンアップして運用状態に戻せるようにします。前フェーズのResponseとの違いは根本的な原因の解決になります。
- ・ システムへの明白な侵入経路を取り除いたとしても、攻撃でインストールされたバックドアやその他のマルウェアを見逃している可能性もあります。
- ・ 侵害されたシステムを解決する一つの方法としてリストアが考えられますが、バックアップに侵入経路がないことを確証するためには、根本原因分析を行う必要があります。侵入以降のバックアップをリストアしても意味がありません。

根本原因分析

- ・ 根本原因分析では、インシデントを発生させた根本的な弱点や脆弱性を明らかにします。根本原因分析を行わなければ、同じ問題に再び直面する可能性が高いです。
- ・ 影響を受けたシステムだけでなく、特定の脆弱性や一連の脆弱性を持つ組織内のあらゆるシステムの脆弱性を修正する必要があります。例えば、脆弱なパスワードポリシーや暗号化がシステム侵害の根本的な原因となっている場合、その脆弱性を取り除くために対策を講じることになります。

なぜなぜ分析

根本原因分析の手法の一つになぜなぜ分析というものがあります。なぜなぜ分析とは、トヨタ生産方式の一つであり、問題を発見したら“なぜ？”を5回繰り返すというものがあります。これにより、今まで見えてこなかった原因が現れてきます。さすがトヨタですね。



インシデント管理

インシデント対応

●インシデント対応のプロセス

⑤報告（Reporting）

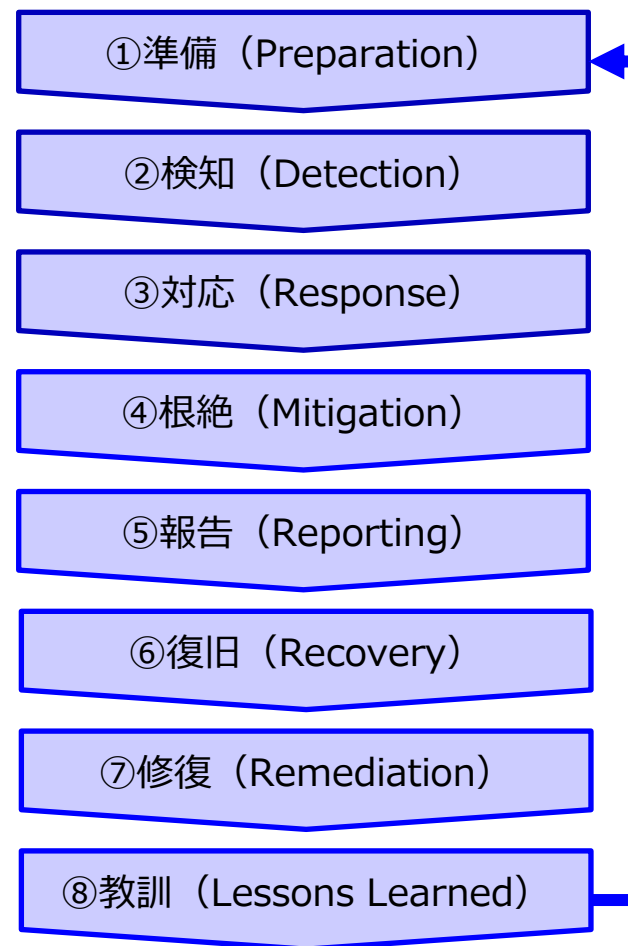
- 原因調査できた事象を分かりやすく説明するレポートを作成します。
- 重大なインシデントについては経営陣にも通知します。経営陣は必要に応じて法務部、広報部など他の部署と協力することを許可します。
- 報告には、システム要件などの技術的なものとヒューマンエラーや体制などの非技術的なものがあります。

⑥復旧（Recovery）

- システムを通常運用可能な状態に復旧します。
- 最新のデータの復旧、ACL（アクセスコントロールリスト）が適切か、不要なサービスが上がっていないかなどをダブルチェックし、通常稼働に戻します。

⑦修復（Remediation）

- システムの脆弱性と解決策を横展開し、システム全体としてのリスクを緩和します。
- 同じ脆弱性を持つ可能性があるすべてのシステムにパッチや改善を要請するなど、より広範な修復が行われます。



インシデント管理

インシデント対応

●インシデント対応のプロセス

⑧教訓（Lessons Learned）

- ・ インシデント対応についての問題を解決し、新たな管理や保護措置を導入します。
- ・ どのようにうまく対処したか、何がうまくいって何がうまくいかなかったのか。次回別の問題が発生したときに組織としてどのように成長し、より良くなることができるでしょうか。
- ・ 最終的にシニアマネージャーに報告し、最終責任者はシニアマネージャーになります。

教育の手法

障害発生後には、新人にも問題の本質を理解いただき、将来同じような問題が起きた際にも解決への探求力をつけさせなければなりません。
体系的な学習も勿論、手順を修正するように依頼すると、今までの手順の見直しを頂く機会にもなります。

代表的な教育手法

- ・ 体系的な学習計画
- ・ シャドーイング
- ・ 検証機を使った実機復旧
- ・ ジョブローテーション
- ・ 運用手順書の修正

①準備（Preparation）

②検知（Detection）

③対応（Response）

④根絶（Mitigation）

⑤報告（Reporting）

⑥復旧（Recovery）

⑦修復（Remediation）

⑧教訓（Lessons Learned）



セキュリティ監視

セキュリティ監視

ネットワーク監視／ホスト監視

●システム監視

- インシデント対応するには、まず検知しなければなりません。
- システム異常を検知するためには監視したい事象に合わせた監視モジュールが必要です。
- 企業のようにITサービスを継続して展開する場合には、アプリケーションのログの情報だけを監視対象とすることはありません。たとえ、アプリケーションのログが出力されない場合には、アプリケーション自体が止まっているケースやそもそもアプリケーションに通信が到達していないケースもあり、システムで起こっているすべての事象がアプリケーションのログに現れるわけではないからです。

クリッピングレベル

- クリッピングレベルは、データ抽出ではありますが、ある閾値を指します。

種類	監視モジュール例
アプリケーション監視	APM
サーバー監視	CPU、メモリ、ディスク使用量
ネットワーク監視	SNMP、フロー監視
セキュリティ監視	auditd、IDS、IPS

セキュリティ監視

ネットワーク監視／ホスト監視

●ネットワークでの不正侵入監視

侵入検知システム（Intrusion Detection System）

- 侵入検知システムとは、システム監視を行い、受動的なアクションにつなげる機構です。
- イベントが発生するとアラートが出し、管理者に通知されます。

侵入防止システム（Intrusion Prevention System）

- 侵入防止システムとは、悪意のあるトラフィックに対してアクションを起こします。
- イベントがトリガーとなり、トラフィックの破棄やリダイレクトを行います。また、監視や管理者の通知と組み合わせられることもあります。

IDS

Intrusion Detection System

検出



警告

IPS

Intrusion Detection System

検出と防止



保護

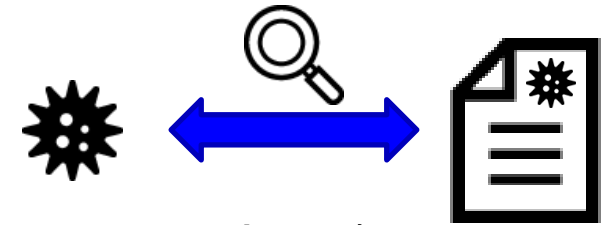
セキュリティ監視

ネットワーク監視／ホスト監視

● 監視対象の検出条件

シグネチャ（パターン）マッチングベース検知（Signature-based Detection／Knowledge-based Detection）

- ・ 既知の悪意のあるトラフィックパターンと一致しているかを照合します。
- ・ トラフィックを悪意のあるパターンと照合するだけであるためより高速です。ただし、ゼロデイ攻撃に弱く、新しい脆弱性パターンに対応するためには常に更新する必要があります。

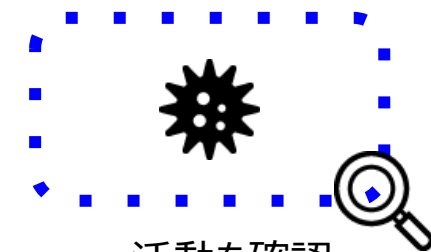


照合して確認

シグネチャ（パターン）マッチングベース検知

ヒューリスティック（行動）ベース検知（Heuristic-based Detection／Behavior-based Detection）

- ・ 「異常とみられる行動」を活動を検出することです。
- ・ パターンが一致しなくとも異常な行動という条件で検知されるため、比較的新しい・未対応の脆弱性に対しても検知が望めます。
- ・ シグネチャーマッピングベースとヒューリスティックベースの両方でチェックすることが望めます



活動を確認

ヒューリスティック（行動）ベース検知

セキュリティ監視

ネットワーク監視／ホスト監視

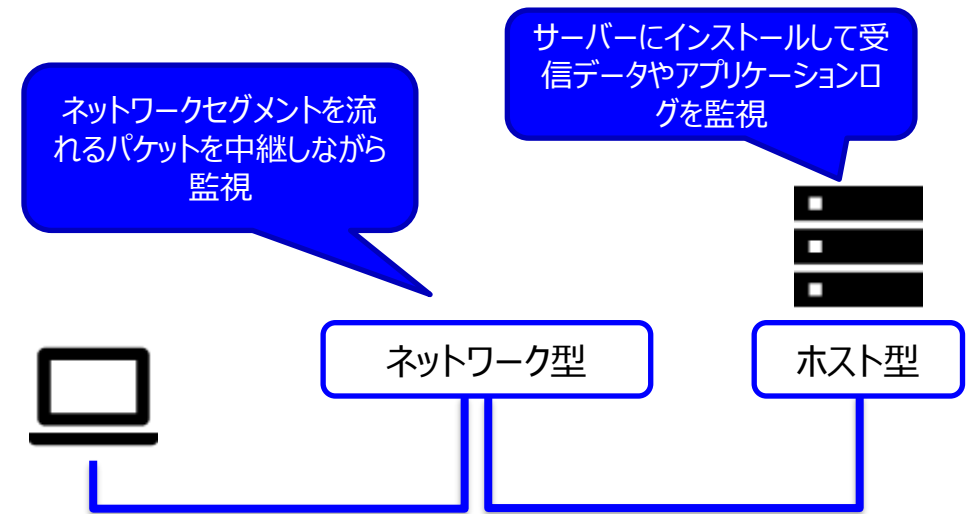
● 監視モジュールの設置場所

ネットワークベース (Network-based)

- ・ 監視モジュールがネットワークセグメント（スイッチポートなど）に設置される構成を指します。
- ・ 送信先のポート、IP、プロトコル、トラフィックのコンテンツを検査しますが、暗号化されたトラフィックは検査できません。
- ・ 1台のスイッチに導入する場合、ポートとNICはプロミスキャスでポートはスパンポートである必要があります。

ホストベース (Host-based)

- ・ 監視モジュールがクライアント（サーバーやワークステーションなど）に設置される構成を指します。
- ・ トラフィックの他、サーバーリソースの使用状況や特定のアプリケーション処理に併せて確認することができます。



セキュリティ監視

ネットワーク監視／ホスト監視

● 監視の精度

フラグメンテーション

- 断片化されたパケットを送信することで、検知される時点では分割されたパケットとなることで攻撃のシグネチャの検知を回避しようとしています。

アドレスの偽装

- 悪意のある送信を識別するために送信元アドレスが利用されます。
- しかし、攻撃者は、セキュリティの低いプロキシサーバを使用して送信元を偽装し、IDS・IPSが攻撃の送信元を検出することを困難にします。

パターン変更回避

- マルウェアが異なる文法で同じ処理をさせるが不要なデータを付属するなどして、パターン検知を回避しようとしています。

True Positive (本当の攻撃を検知する) 	True Negative (本当の攻撃を検知しない) 
False Positive (偽の攻撃を検知する) 	False Negative (偽の攻撃を検知しない) 

検知の分類はパターンは4つに分類される

セキュリティ監視

ネットワーク監視／ホスト監視

● 不要な検知の回避方法

警告バー（Warning banner）

- ・ システムが異常の挙動として検知するのは、100%悪意のあるユーザーによるものではありません。善意によるユーザーが意図しない操作によって、システムが異常と検知することもあります。
- ・ 善意のユーザーの意図しない操作によって生じる検知を抑止するためには、警告画面を表示する事が有効です。
- ・ 積極的なアプローチでは、警告以降の操作を監視することを通知します。



不正な操作については、ユーザーに
知らせることも重要

セキュリティ監視

静的検知／動的検知

● 動的な検知

ハニーポット (Honeypot)

- ・ ハニーポットとは、実際の本番運用システムのように見えるが攻撃者を惹きつけることを目的としたシステムです。
- ・ ハニーポットはプログラム挙動を確認する環境であるために、完全な強化は不要です。ハニーポットの結果から、実際の運用サーバーを強化することが目的です。
- ・ ハニーポットは、攻撃を誘発させることを目的としません。それは非倫理的な行動になります。非常に明確な法的ガイドラインを発行し、シニアマネージャーの承認を得る必要があります。

ハニーネット (Honeynet)

- ・ ハニーネットは、実際の本番運用システムのように見えるが攻撃者を惹きつけることを目的としたネットワークを指します。
- ・ 目的はハニーポットと同じですが、ハニーネット上のトラフィックを観察できるようになっています。

サンドボックス (Sandboxing)

- ・ サンドボックスとは、挙動の不明なソフトウェアの実行環境として用意された、外部へのアクセスが厳しく制限された隔離領域のことです。
- ・ 悪意のあるソフトウェアは実行した時点でネットワーク経由で感染を広げる可能性があり、ネットワーク隔離された状態で動作確認を行う必要があります。

セキュリティ監視

マルウェアの難読化

●マルウェアの難読化

マルウェアの検知方法

- 静的な解析による検知では、マルウェアファイル内の文字列一致で検知する方法です。
- 動的な解析による検知では、閉鎖されたサンドボックス環境にて、実際の挙動を確認する方法です。

検知を逃れる手法の代表例

- パッカーとは、実行ファイルの中身を圧縮し実行時に解凍する（パッキング）を行うこと、もしくはそのツールです。圧縮されている＝パターン検知できないため、検知を逃れます。
- 一定の条件や一定時間がたたないと攻撃に転じないマルウェアは、すぐに悪意のある挙動に転じないため、無害なマルウェアとして扱ってしまう可能性があります。



① 実行ファイルの中身を圧縮化



② 中身が圧縮されているため、ただの不規則な文字列に見える。



③ 解凍し、実行

パッカーによるパターン検知の回避例



① 検査期間は実行されない



② 実用端末にインストールし、一定時間たったら、実行

時間差によるパターン検知の回避例

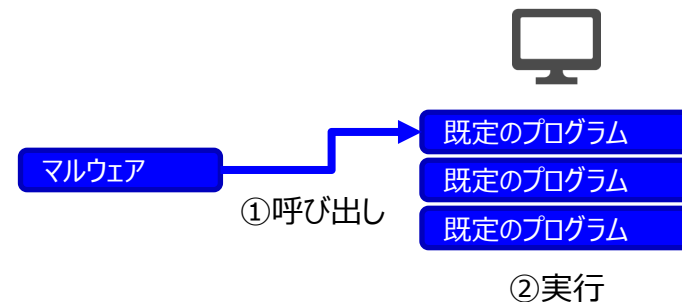


セキュリティ監視

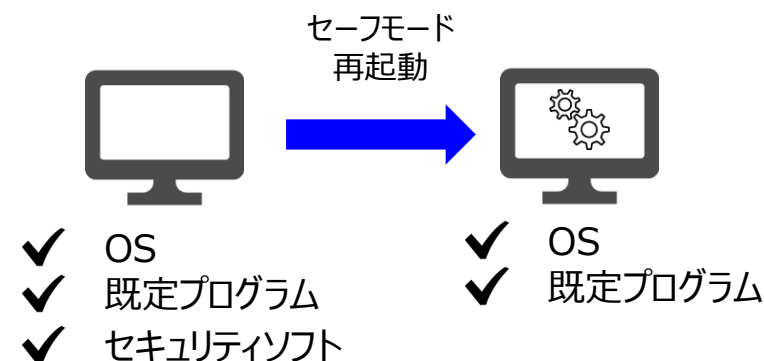
マルウェアの難読化

●マルウェアの難読化 検知を逃れる手法の代表例

- LOL攻撃とは、攻撃対象となる環境で正規と見なされているプログラムを利用する攻撃です。セキュリティソフトは「正規のプログラムが実行するなら安心である」という判断になり、それを受け入れてしまいます。
- セーフモードは、OSに何かしらの大きな欠陥があった場合に起動するモードであり、確実に起動するために必要最低限の機能しか呼び出されないことになっています。セーフモードで再起動されると、セキュリティソフトを実質機能しない環境が作られます。マルウェアは、自身を起動時に実行されるようにし、セーフモードでの再起動をOSにさせようとしています。



LOLによるパターン検知の回避例



セーフモードによるパターン検知の回避例

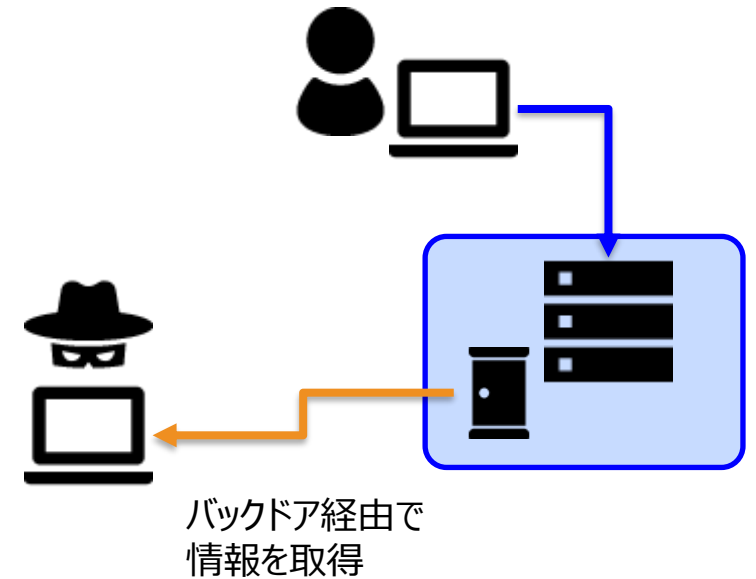
セキュリティ監視

マルウェアの難読化

●マルウェアの難読化

バックドア（Backdoor）

- 最初の攻撃が終わった後にシステムへのアクセスを可能にしたり、時間をかけてデータを流出させたり、他のシステムを侵害するために設置されます。
- コンピュータシステム、製品、または組み込みデバイスにおける通常の認証をバイパスとします。
- コンピュータへのリモートアクセスを確保することで、攻撃タイミングをずらし、潜在的な脆弱性になる可能性が高くなります。

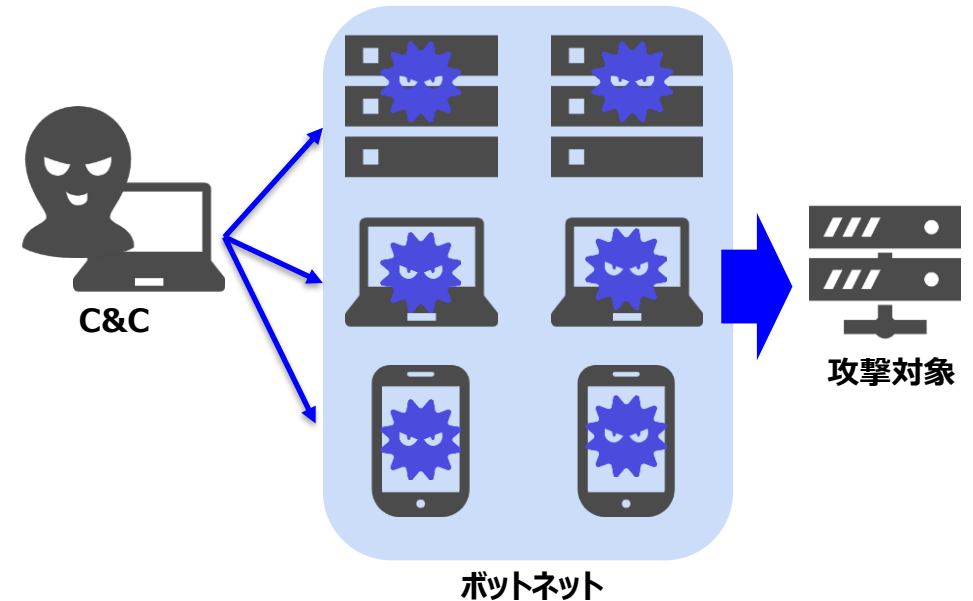


セキュリティ監視

マルウェアの難読化

●マルウェアの難読化

- ボットとは、ネットワーク経由で遠隔からコマンドを実行できる悪意のあるプログラムです。
- ボットが行う感染しているコンピュータは一般の我々のスマートフォンやパソコンです。当の本人であっても、ボットに感染していることはほとんど気づけません。
- 自身の知らないうちに外部からの命令を受け、DDoS攻撃などのサイバー攻撃の踏み台とされてしまい、あなたの端末が攻撃に加担する可能性があります。
- ボットネットとは、ボットを束ねたネットワークであり、攻撃者はC&Cサーバー（Command and Control server）でボットに対し命令を出して攻撃を行います。



攻撃者はボットネット利用することで
正規の端末から大量の攻撃を仕掛けることができる

セキュリティ監視

統合監視

● SIEM (Security Information and Event Management)

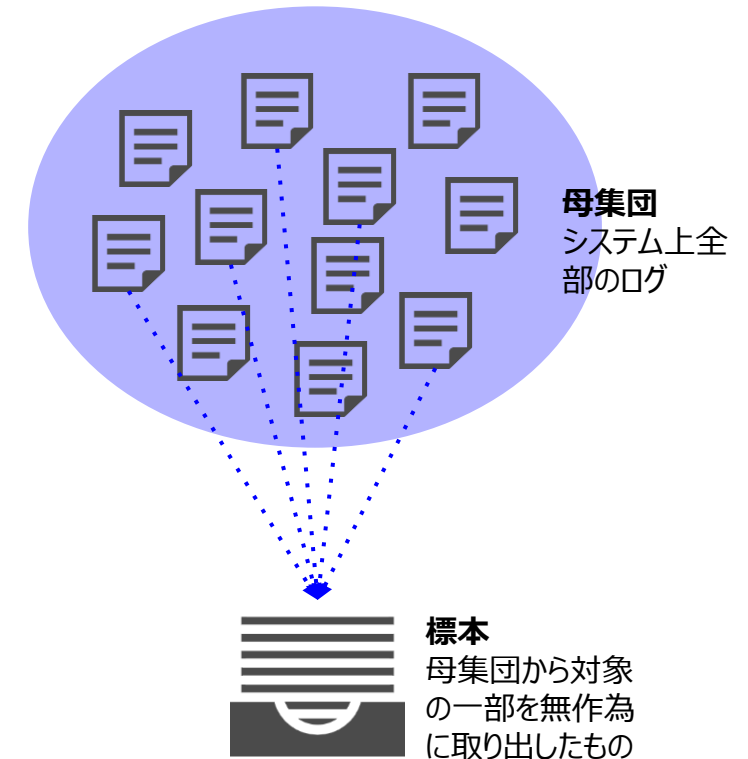
- SIEMは、ファイアウォールやIDS/IPS、プロキシなどから出力されるログやデータを一元的に集約し、システムの全体像を把握することで、サイバー攻撃やマルウェア感染などのインシデントを検知する仕組みです。

データの相関分析

- UEBA (User and Entity Behavior Analytics) とは、蓄積されたデータをもとにユーザーの行動を特定し、システム上のトラフィックパターンが正当なユーザーのものか、攻撃者のものかを判断する分析です。
- 現代では、SIEMにおいて統計的分析や機械学習を用いた分析機能と認識しておいてよいでしょう。

サンプリング (データ抽出)

- サンプリングとは、調査対象となる母集団の中から直接調査を行うサンプルを抽出することです。



サンプリング標本の計測値の特性から
母集団の特性を統計的推測をする

セキュリティ監視

統合監視

●SOAR (Security Orchestration, Automation and Response)

- SOARとは、セキュリティインシデントの監視、理解、意思決定、アクションを効率的に行えるようにする技術です。
- 一般的に、SIEMで分析・検知された結果に対して適切なセキュリティ対応を示します。

プレイブック (Playbook)

- ドキュメントやチェックリストなどのインシデントを検証する方法をフロー図をベースに定義しています。

ランブック (Runbook)

- プレイブックのデータを自動化ツールに適用する事です。これにより、インシデントをプレイブックによって定義し、プレイブックの対応を自動化します。

機械学習

- 定型的な自動化が行われた後は、機械学習が望まれています。
- インシデントからプレイブックに定義する学習領域に関しても、システム化する動きがあります。



プレイブック (Playbook)

(<https://www.rsa.com/content/dam/en/in-fographic/see-what-rsa-netwitness-orchestrator-can-offer.pdf>)

セキュリティ監視

統合監視

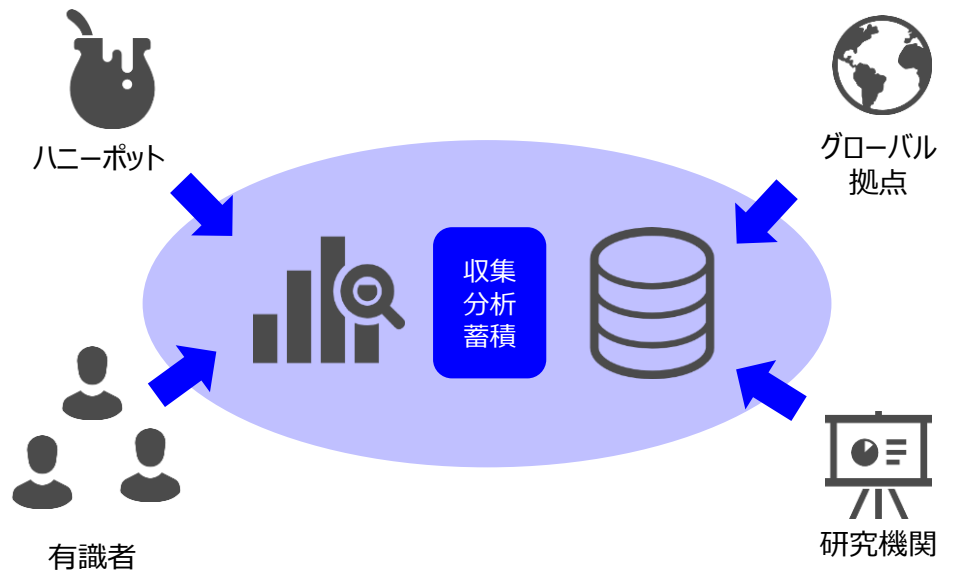
● 脅威情報の取得

脅威インテリジェンス (Threat Intelligence)

- ・ 世界中のネットワークに監視網を張り巡らせ、IPアドレスベースで行動を監視し、悪意度を算出します。この悪意度は、脅威のブロックやフィルタリングに活用できる脅威情報として提供します。
- ・ 脅威フィードは、攻撃者のIPアドレス、ドメイン、マルウェアのハッシュ値などの最新情報をリアルタイムで提供する仕組みです。
- ・ 脅威ハンティングは、既存のセキュリティシステムや脅威インテリジェンスを活用し、システム内に潜む脅威や侵入経路を能動的に調査・特定するプロセスです。

セキュリティ侵害インジケータ (Indicators of Compromise)

- ・ セキュリティ侵害インジケータとは、サイバー攻撃を受けていることを示す痕跡です。
- ・ 他の組織と情報を連携の標準がOpenIOCです。OpenIOCはIOC FinderとIOC Editorという早期に攻撃を発見できるような管理者用ツールを提供しています。



あらゆる情報からスレットインテリジェンスとして
調査する

セキュリティ監視

出口監視

● 出口監視 (Egress monitoring)

- 出口監視は、ネットワークから出ていくアウトバウンドトラフィックを監視し、潜在的なデータ漏洩や損失を発見するプロセスです。

● ステガノグラフィー (Steganography)

- ステガノグラフィーとは、情報を他の無害なデータに隠す技術のことです。目的は、隠された情報を第三者に気づかれずに伝達することです。
- 暗号技術 (Cryptography) とは異なり、ステガノグラフィーは情報そのものを隠蔽し、秘密のメッセージが存在することを秘匿します。

画像内にテキストを埋め込む



画像のピクセルの最下位ビット (LSB: Least Significant Bit) を使って、テキストメッセージを隠す方法です。

音声ファイルにメッセージを隠す



音声の周波数帯域に変更を加え、聴覚的には気づかれない範囲で情報を埋め込みます。



運用管理

運用管理

運用ルール／運用フロー

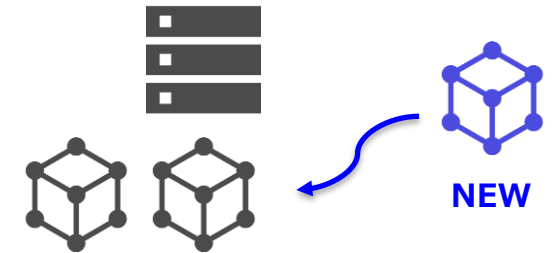
● システム管理

システム運用の目的

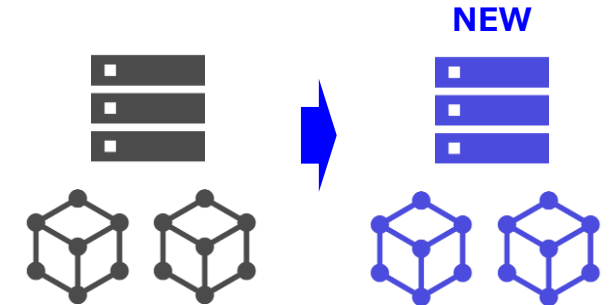
- ・ システム運用は、リリースされた後のサービスを安定稼働し、効率的なサービス提供するために行われます。
- ・ 24時間稼働させるのか、日中帯だけ稼働させるかなど運用方針はサービスごとに異なるため、サービスに合わせた運用の最適化が行われます。
- ・ 運用のルールを変更するタイミングは大きく2つあります。1つ目は、既存の基盤に新しいシステムやサービスを導入した時です。2つ目は、既存の基盤を新しい基盤に更改する時です。

アプリケーション開発と運用チーム

- ・ アプリケーションを開発するチームとそのアプリケーションを利用したサービスを運用するチームは異なります。
- ・ アプリケーション開発を行う際には運用しやすい設計、開発環境から運用環境への迅速なパイプラインの確保を行います。



既存基盤に新しい機能・アプリケーションを導入する



新規基盤に既存機能・アプリケーションを移行する

運用管理

運用ルール／運用フロー

● システム管理 運用テスト

- 運用テストでは、アプリケーションの運用が可能であるかどうかを確認します。
- メンテナンス画面に切り替えるか、障害検知が行われるか、障害が起きた後のサービスの復旧手順などの運用フローを担保する運用手順書を確認します。

運用テストの成果物

- 運用フローとは、システムや利用者からの問い合わせに対して、だれに連絡を取って、どの手順を見るべきなのかを網羅したフロー図です。
- 運用手順書とは、主にシステム設定の何を修正すべきなのかを把握するためのステップバイステップの資料です。誰が行っても同じ結果になる明瞭さが求められます。手順を簡略化するために、一部の手順を自動化するツールの開発も行われます。



運用フロー



運用手順書



運用管理

運用ルール／運用フロー

● 監視管理

- ・ システムの一部に支障をきたしているとき、障害が発生している可能性があります。
- ・ システムのログ、サービス起動状態や疎通状態から監視アラートを上げ、運用管理者に連絡する必要があります。
- ・ 監視アラートを上げる条件はシステムごとに異なります。例えば、一部のサービスが止まった場合には緊急に通知すべき事にも思えますが、冗長化されていれば、全体としてのダウンタイムにはつながりません。
- ・ 緊急に対応が必要なのか、警戒が必要なのかは、そのサービスの停止の影響度から判断されます。

監視名	監視内容
死活監視	PING通信により機器やOSへの疎通を確認する。
ハードウェア監視	SNMPによりハードウェアの異常などを確認する。
リソース監視	CPU、メモリ、ディスクの使用率が閾値を超えていないかを確認する。
プロセス監視	OS上で動作しているプロセスやサービスが起動し続けているかを確認する。
ログ監視	OSやミドルウェアやアプリケーションのログの中身からログレベルが高く緊急性のあるものを確認する。
HTTP監視	HTTPリクエストを送付することによりアプリケーションレイヤーへの疎通を確認する。

運用管理

運用ルール／運用フロー

●ログ管理

ログ管理の目的

- 障害調査では、障害発生した場合に、原因を特定するため調査です。

ログローテーション

- ログローテーションは、ログを一定期間でクリアにし、元のログは別名にします。大抵、別名保管されたログは他のサーバーに移動させ、元のサーバーから削除します。

ログ管理の注意点

1. ログを集めてレビューしない。
2. ログが十分な時間保管されていない。
3. ログのフォーマット等が標準化されていない。
4. ログ監視のアラートなどに優先順位がない。
5. システムエラーログなどの悪いログだけ見る。

1日目



access.log

2日目



access.log



access_01.log

3日目



access.log



access_02.log

削除



access_01.log

1 日間隔でログローテートされ 3 日目以降で削除する例

運用管理

運用ルール／運用フロー

● バックアップ/リストア管理

- データベースやアプリケーションファイルのバックアップは、定期的にとることが望まれます。
- ジョブ管理されたコマンドでバックアップ管理が行われ、例えば 1 週間に 1 回など定期的に自動的に実行されます。
- 急なシステムへのアップデートがある場合には、作業前に作業対象システムへの緊急のバックアップが取られます。

● ジョブ管理

- 深夜帯に各サーバーのログのファイルを保存用のストレージに移動させるなど、システム運用上定期的に行う業務があります。このような定期運用業務はシステム内で自動化されることが望ましいでしょう。
- ジョブとは、人間の代わりに実行されるシステムへの業務作業の命令です。ジョブ管理システムによって、各ジョブを定義し実行時間を割り当てます。
- 具体的な作業ではなく、運用業務を行うにあたっての定型作業の自動化管理になります。

バックアップするためだけに深夜作業なんて…



手動



深夜になりましたので、「バックアップするコマンド」を実行します。



ジョブ実行

運用管理

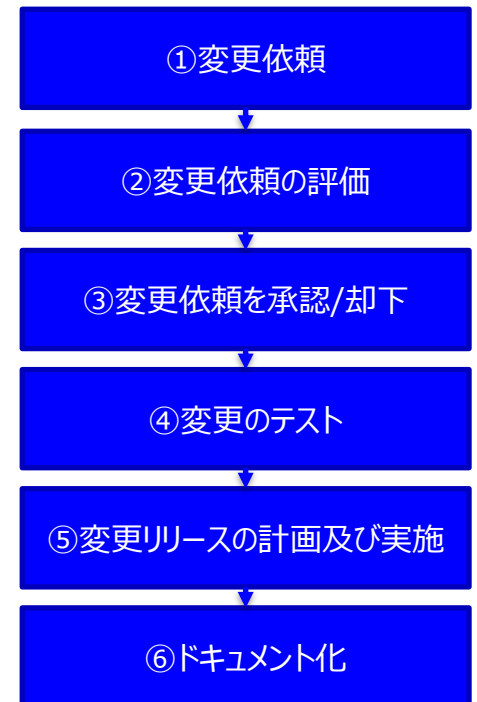
変更管理

● 変更管理

- ・ 変更管理とは、環境に変更が必要である場合にその変更を適切に行うプロセスです。
- ・ 影響の大きな脆弱性によって緊急対応をしなければなりません。その場合、管理者はドキュメント化を先に実施し、潜在的なリスクを洗い出しておくことが重要です。

変更管理プロセス

1. 変更依頼：運用管理者や顧客の問い合わせによって、変更依頼がかけられます。
2. 変更依頼の評価：変更依頼に対してシステム専門家（システム管理者など）がその変更が適切であるかを評価します。
3. 変更依頼を承認/却下：システム専門家（システム管理者など）が仮承認か却下かを判定をします。
4. 変更のテスト：承認された変更依頼は、実運用サーバーでない開発サーバーでテストされます。期待する結果となることを確認します。
5. 変更リリースの計画及び実施：影響を受ける関係者への変更通知をします。ピークでない時間帯を調査し、切り戻し計画を準備したうえで実行します。
6. ドキュメント化：変更箇所に対して文章化します。



運用管理

変更管理

● 変更管理

要求管理

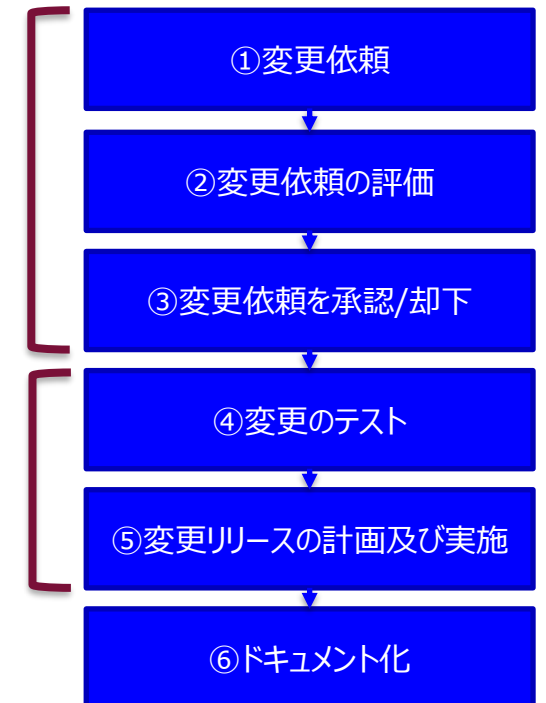
- 要求管理とは、問い合わせやインシデントの要求に対して、対応漏れが出ないように管理することです。
- 要求ごとに優先度の評価も行い、どの要求から対応すべきなのかも決められます。

リリース管理

- リリース管理とは、製品リリースの際にテストを含め適切に行われ、影響を少なくリリースすることを管理することです。
- 要望に対するリリース期限、リリース順序、時間帯、関係者への報知などが含まれます。
- リリースはパッチの適用や新機能の搭載、既存バグへの修正などがあり、またサービスの停止を行うかどうかの判断も内容によって異なります。どのリリースから行うべきなのかも含めて管理しておく必要があります。

要求管理

リリース管理

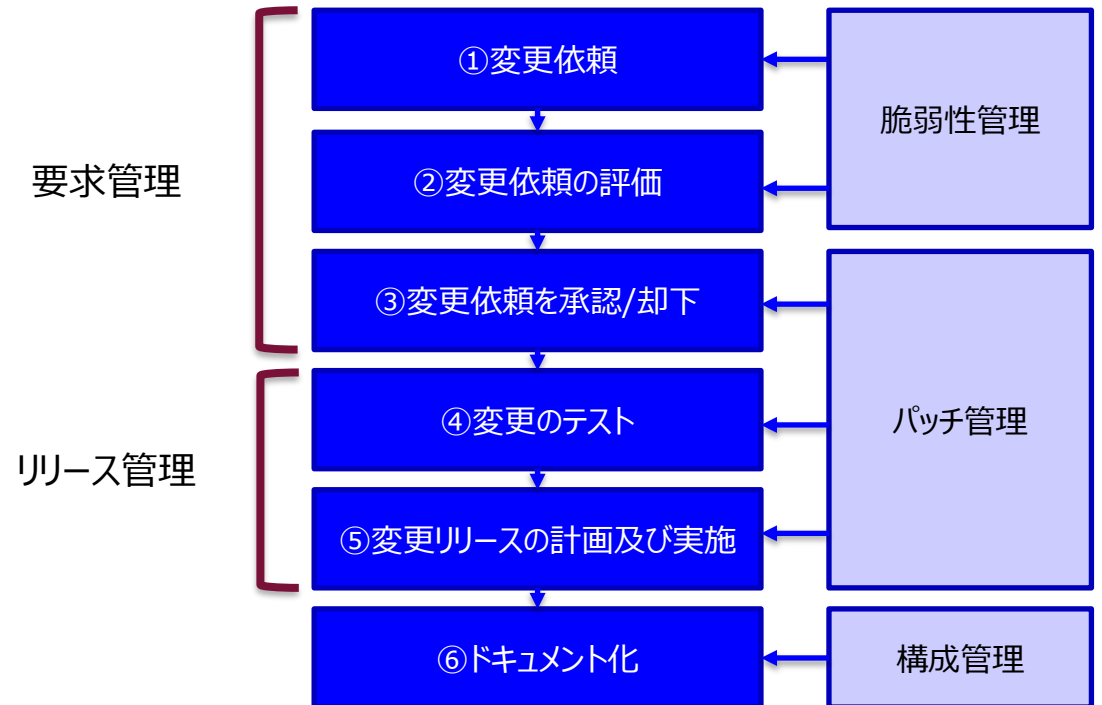


運用管理

構成管理

● 構成管理

- ・ 構成管理とは、システム上で何処に何の製品がどのバージョンであるのかを管理することです。
- ・ システムはいくつもの製品からなります。何がどこにあるのか、いつのバージョンのものなのかを把握しておかないとそのバージョンがサポート切れを起こす場合であっても管理者が気づけない可能性があります。

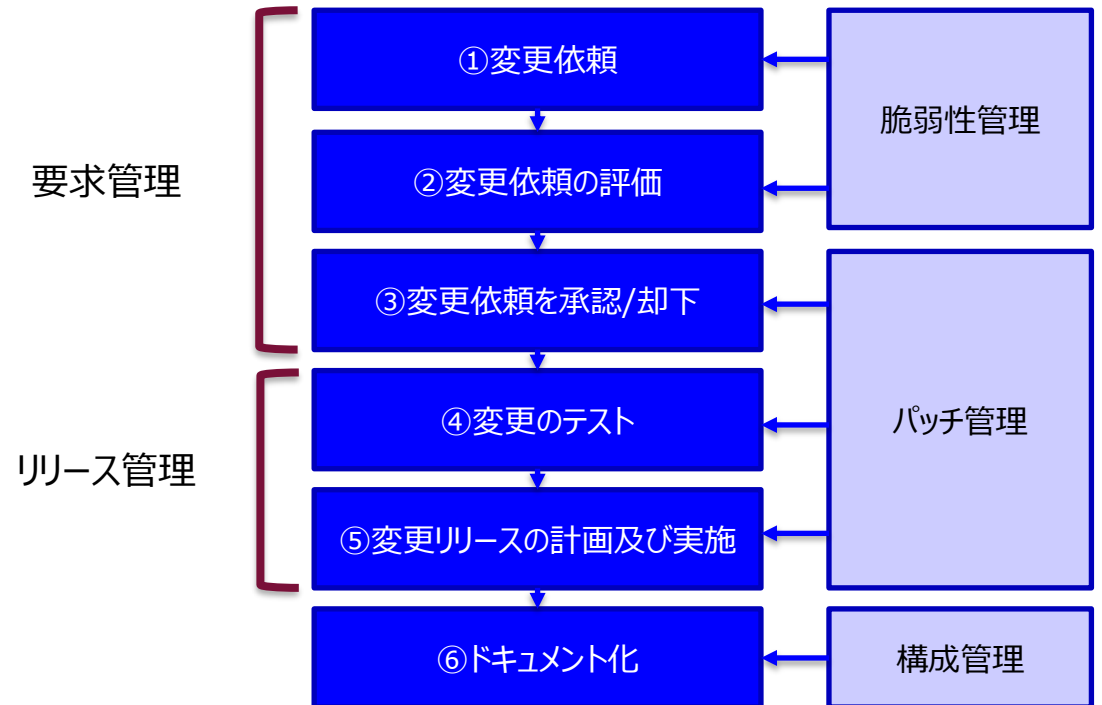


運用管理

脆弱性管理／パッチ管理

●脆弱性管理

- 脆弱性管理とは、システムの脆弱性を特定し、評価・解消することです。
- 自システムの各コンポーネントに対して、最新の脆弱性情報を確認し、脆弱性が存在しているかを確認します。
- 脆弱性が発見されれば、ベンダーから公開されている修正パッチをパッチ管理に従って適用します。



運用管理

脆弱性管理／パッチ管理

●パッチ管理

- パッチとはバグや脆弱性もしくは機能改善によって修正されるプログラムであり、パッチ管理ではパッチをいつ適用どのモジュールに適用するのかを管理します。
- 商用サービスに関するセキュリティパッチはソフトウェア開発側から公開されます。

パッチ管理のプロセス

1. パッチの評価：パッチの内容を確認し、どのような機能変更が行われるのかを確認します。
2. パッチのテスト：実運用サーバ以外のサーバにてパッチを適用した場合の影響について実検証します。
3. パッチの承認：適用しても問題がないことが確認できたところで承認を取得します。
4. パッチの適用（デプロイ）：パッチを実運用環境に適用します。SCCM（System Center Configuration Manager）等の構成管理ツールによって、多数のコンピュータをネットワークを通じてパッチを適用することも可能です。
5. 適用されたパッチの検証：最後にパッチが適用されたかどうかを確認します。

Patch Tuesday

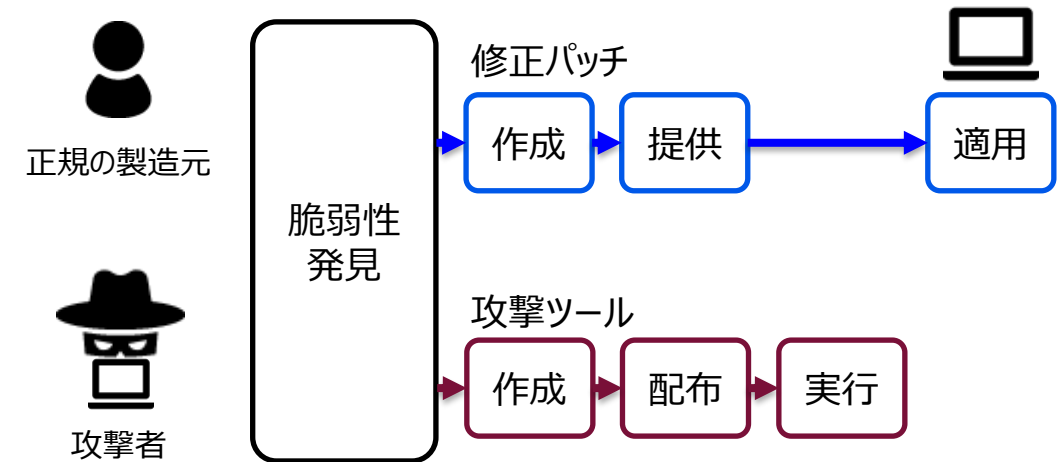
Microsoft、Adobe、Oracleの製品のセキュリティ更新プログラムの公開時期は決まっています。毎月第2火曜日（米国時間）にリリースされ、“Patch Tuesday”と呼ばれています。

運用管理

脆弱性管理／パッチ管理

●ゼロデイ攻撃

- ゼロデイ攻撃とは、一般的に知られていないあるいは発見されていない脆弱性を狙う攻撃のことであり、初めて攻撃が確認された日を「0日」といい、その名前の由来となっています。
- 脆弱性が発見されてから、主要なソフトウェアにパッチやシグネチャがリリースされるまでの期間は短いですが、その間は脆弱性が公開されているが対応していないシステムがあるため、攻撃を行います。
- ゼロデイ攻撃に対する防御は、迅速にセキュリティパッチを適用することです。



脆弱性が発見されたことは正式の製造元だけに伝わるわけではない。

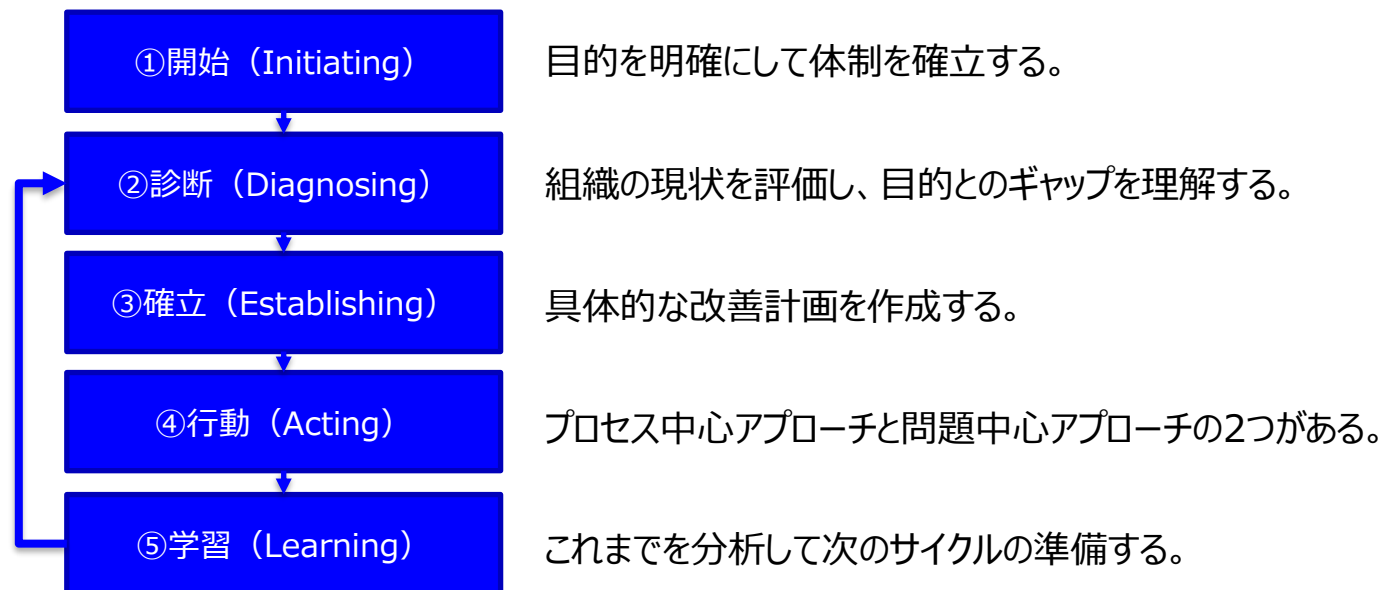
運用管理

継続的な改善

● 運用改善

IDEALモデル

- IDEALモデルとは、プロセス改善のモデルの一つです。目標の達成や現状の回復のため、改善は常に必要です。改善を正しく行うためにプロセスを理解しておかなければなりません。



運用管理

特権アカウントの管理

●特権アカウント管理（Privileged Access Management）

- 特権アカウント管理（PAM）は、ローカル管理者アカウント、Domain Admins、Linuxのrootアカウントなど特権アカウントのアクセス制限や監視を行い、セキュリティを強化するソリューションです。
- 特に管理的コントロールと技術的コントロールの両方の観点から保護施策を考える必要があります。

特権昇格（ Privilege escalation ）

- OSやアプリケーションのバグ、設計上の欠陥、設定の不備などを利用して、通常はアプリケーションやユーザーから保護されているリソースにアクセスすることです。
- 攻撃者の目的は、アクセス権を得たユーザーアカウントを昇格させ、管理者権限を取得することです。
- アプリケーションの開発者やシステム管理者が意図した以上の権限を持ったアプリケーションが不正な動作を行うことになります。

ジョブローテーション（ Job rotation ）

- ジョブローテーションとは、ある業務を定期的に持ち回ることであり、個人による不正を発見しやすくなり、共謀の可能性も低くする効果があります。
- 従業員の燃え尽き防止や従業員が業務全体を理解するのに役立ちます。



フォールトトレランス

フォールトトレランス

サービスレベル合意（SLA）

● 契約

サービス品質保証（SLA、Service Level Agreements）

- サービス品質保証とは、利用量や障害復旧などのサービス品質の合意です。
- クラウドといったインフラ設備やプラットフォームに対して、システム稼働における可用性や性能といった品質項目と水準を定めます。

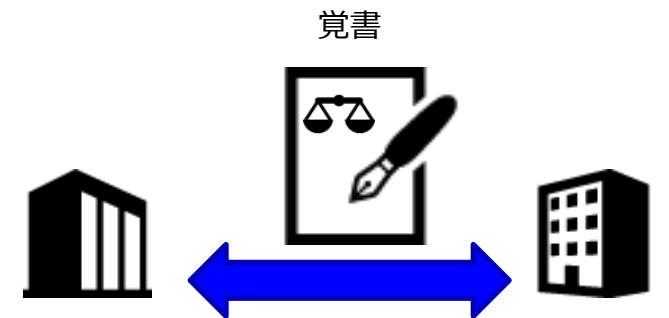
覚書（MOU、Memorandum of Understanding）

- 覚書は、2つ以上の当事者間で交わされる非拘束的な合意を指します。
- MOUは正式な契約書ではないものの、合意した内容やその範囲を明確化し、将来的な正式契約の基礎を築くために用いられます。
- MOUは拘束性が低いため、複数の組織が同じ設備を使用する場合、適切なセキュリティ要件を定めないと、情報漏洩のリスクが高まります。

Service Level Agreements



Memorandum of Understanding



フォールトトレランス

クラスター

● 情報システムに対するフォールトトレランス

SPOF (Single Point Of Failure)

- SPOF (Single Point Of Failure) とは、一つの障害ポイントにより、システム全体が停止される構成を指します。
- 1つのサーバや1つのDBや 1つのアプリケーションに障害が発生しただけでダウンすることは望まれません。
- 障害が発生した際に、システムとして耐えうる（フォールトトレランス）対策を講じる必要があります。

フェールオーバー／フェールバック

- フェールオーバーとは、プライマリコンピューターからセカンダリーコンピューターにトラフィックの主を変えることです。つまり予備への切り替えです。
- フェールバックとは、セカンダリーコンピューターからプライマリコンピューターにトラフィックの主を変えることです。つまり本運用への切り戻しです。

フォールトトレランス

クラスター

● クラスター化

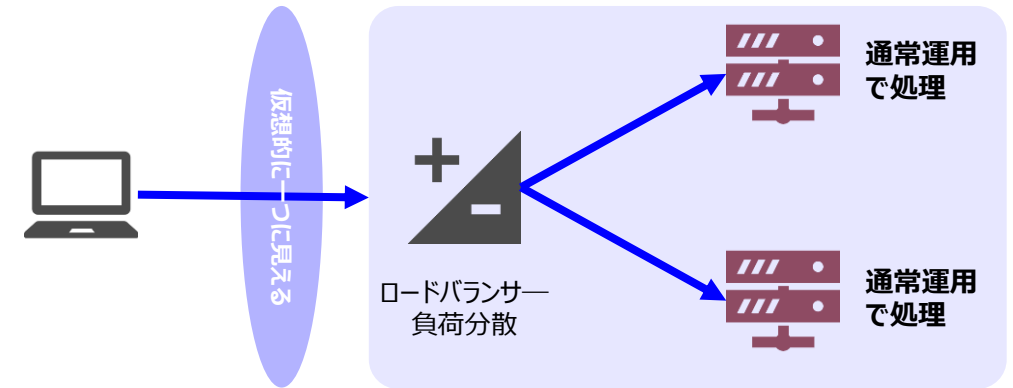
- クラスター化すると、複数の同じコンピュータが仮想IPで接続され、クライアントからは1つのコンピュータとして見えます。

Active/Active構成

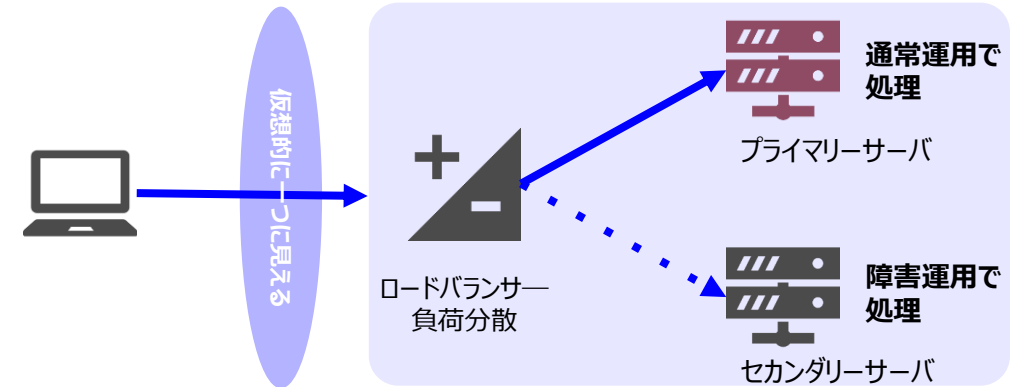
- クラスターを構成するサーバはどちらもトラフィックを受け入れる状態であり、負荷分散でトラフィックが分散されます。
- 両系の性能を確保することができます。ただし、消耗が両系にかかるため両系ダウンの可能性もあります。

Active/Standby構成

- 通常運用時用サーバーと障害時用サーバーを分けます。
- キープアライブまたはハートビートをプライマリアクティブサーバー送信し、プライマリアクティブサーバーが応答する限り、プライマリアクティブサーバーに処理を行ってもらいます。



Active/Active構成



Active/Standby構成

フォールトトレランス

バックアップ

● バックアップ

バックアップポリシー

- バックアップ手法には、フルバックアップ、増分バックアップ、差分バックアップ、コピーバックアップがあります。どれだけのデータを失うことに耐えられるか、バックアップと復元のプロセスをどれだけ速くしたいかによって決まります。
- バックアップは営業時間外に行うことが望ましいです。
- OS、ゴミ箱、特定のプログラムフォルダなど、バックアップするシステムの一部を除外したいことがよくあります。重要なものをバックアップし、すべてをバックアップしないことはおかしいことではありません。



フォールトトレランス

バックアップ

● バックアップ

完全（フル）バックアップ（ Full backup ）

- フルバックアップとは、データベース全体またはシステムのすべてをバックアップします。大規模なデータセットになるため、フルバックアップに何時間もかかることもあります。
- フルバックアップでは、すべてのアーカイブビットが消去されます。

アーカイブビット

- アーカイブビットとは、前回のフルバックアップまたは増分バックアップ以降にファイルが変更されたかどうかを示すフラグです。
- WindowsのNTFSではファイルにアーカイブビットが設定されています。

コピーバックアップ

コピーバックアップとは、フルバックアップのことですが、アーカイブビットがクリアされない特徴があります。

システムのアップデートやパッチなどのアップグレード前などの、バックアップサイクルを乱したくないが何かあったときに以前の良い状態に戻せるようにしておきたい目的で使われます。

フォールトトレランス

バックアップ

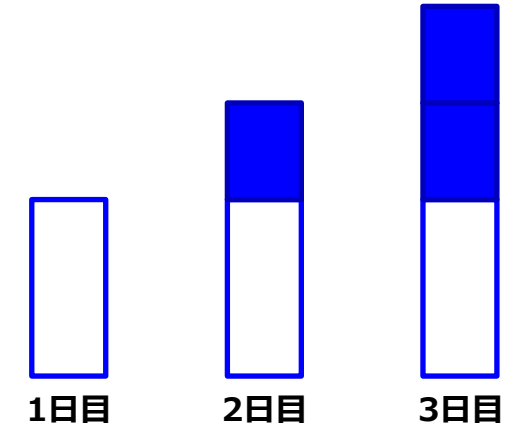
● バックアップ

差分バックアップ（ Differential backup ）

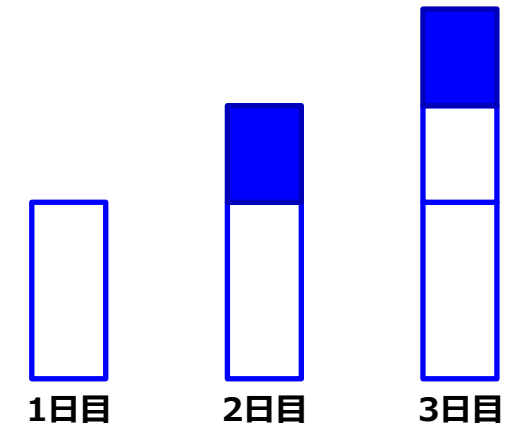
- 差分バックアップとは、最後のフルバックアップ以降のすべてのデータをバックアップします。その際に、アーカイブビットは消去されません。
- フルリストアに必要なテープは、フルと差分の2本だけなので、リストアが早くなります。

増分バックアップ（ Incremental backup ）

- 増分バックアップとは、最後のバックアップから変更されたデータをバックアップします。その際に、アーカイブビットを消去します。
- 不利な点は、増分のバックアップ数が多い場合、フルリストアを行う際にバックアップ数とリストア時間を要することです。



前回フルバックアップからの差分をバックアップ



前回バックアップからの増分をバックアップ

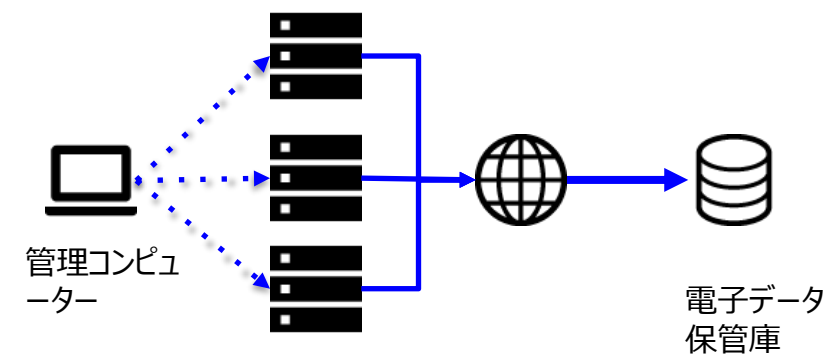
フォールトトレランス

バックアップ

● バックアップ

電子データ保管庫 (e-vaulting)

- 電子データ保管庫とは、リモートバックアップサービスを利用して、一定の間隔またはファイルが変更されたときに、バックアップをオフサイトに電子的に送信することです。
- 災害時の施設の破壊を想定し、地理的に別の場所に、別のメディアでコピーすることが推奨されています。



リモートに存在する電子データ保管庫にローカルデータを保管する

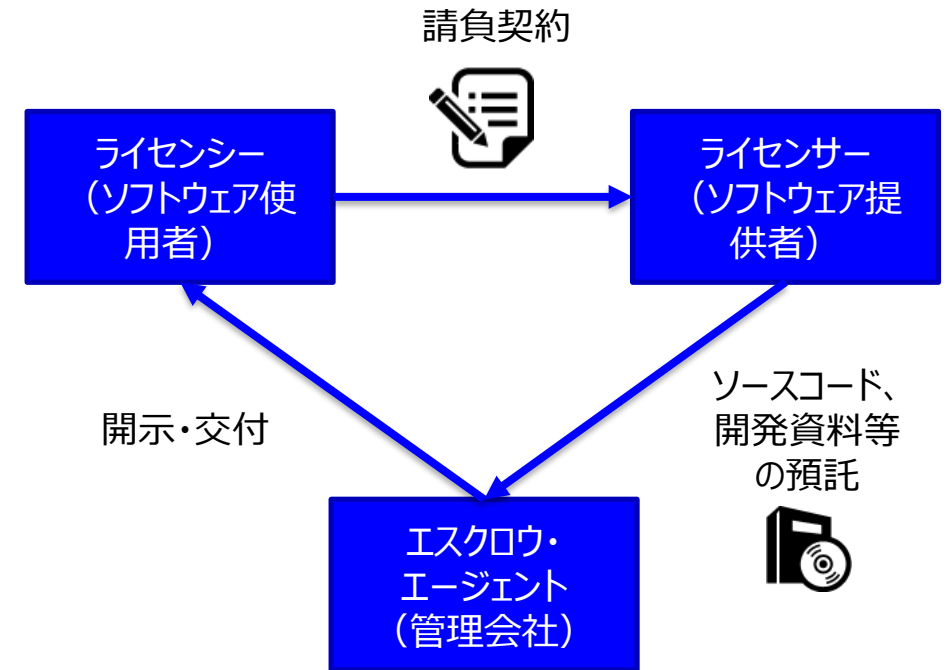
フォールトトレランス

バックアップ

●ソフトウェア開発／運用のバックアップ

ソフトウェア・エスクロウ

- ソフトウェア・エスクロウとは、ソフトウェアのライセンスを販売している以外の組織に預けることです。
- 企業向けソフトウェアには、利用する権利であるライセンスの購入が必須です。しかし、企業が倒産してしまうとライセンスを提供することができなくなります。こうなると、次に困るのがライセンスを購入して、使っている企業です。そのため、ライセンスを第3組織（エスクローエージェント）に預け、運用を続ける方法があります。



フォールトトレランス

メディア保護技術

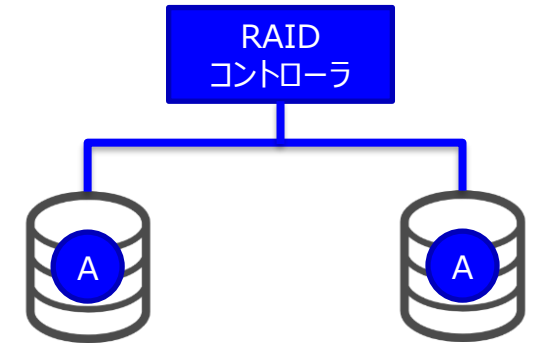
● ディスクの冗長化

ディスクミラーリング

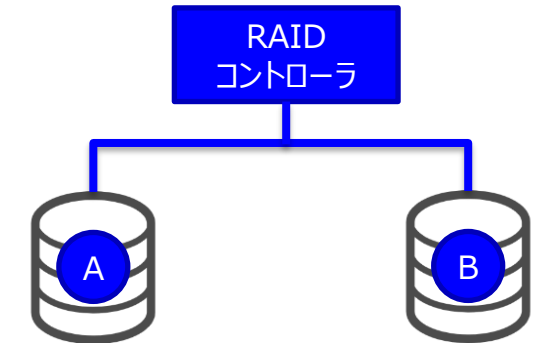
- ディスクミラーリングとは、RAIDコントローラが同じデータを複数のハードディスクに書き込むことです。
- 同じデータを保存するのに最低でも2倍の数のディスクを使用するため、最低でも2台のディスクが必要となります。

ディスクストライピング

- ディスクストライピングとは、RAIDコントローラが複数のディスクに同時にデータを分離して書き込むことです。元のデータに戻す際には、再度組み合わせが必要になります。
- 冗長性を確保するためにストライピングと同時に他のディスクのデータが変わっていないかを確認するパリティを使用します。パリティを使用して冗長性を確保する場合は、少なくとも3台のディスクが必要です。



ディスクミラーリングで複数のディスク
に同じデータを書き込む



ディスクストライピングで分割して別
のディスクに書き込む

フォールトトレランス

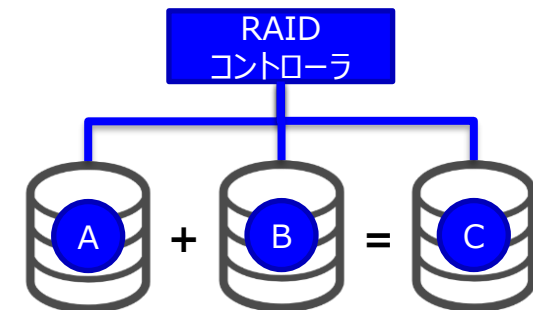
メディア保護技術

● ディスクの冗長化 パリティ

- パリティとは、複数のデータから算出できる演算結果です。例えば、 $A + B = C$ ということを計算して置けば、たとえBが消えたとしても $C - A$ で算出できます。Cがパリティを指し、Bが破損したディスクのデータを指します。
- デジタルの世界は2進法ですから、演算にも排他的論理和が使われます。排他的論理和メンドイ方向けに2進数を奇数・偶数で示しますが、“Aは奇数 + Bは偶数 = Cは奇数”であれば、たとえBが消えたとしても算出できるでしょう。
- ただし、AもBも破損してしまうと、どちらのディスクに何のデータが入っていたかが分からなくなってしまう復旧できません。

排他的論理和

A	B	XOR
0	0	0
0	1	1
1	0	1
1	1	0



フォールトトレランス

メディア保護技術

● RAID (Redundant Array of Independent/Inexpensive Disks)

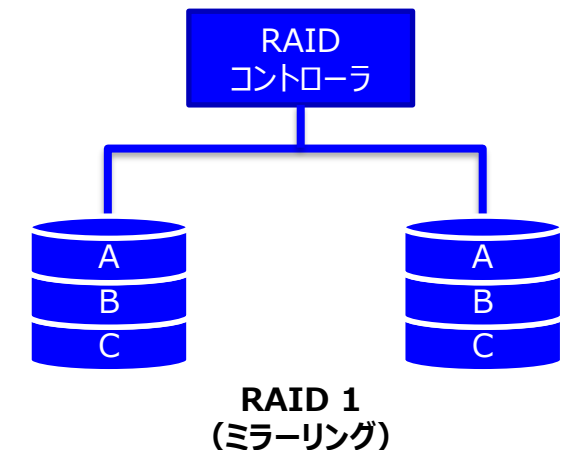
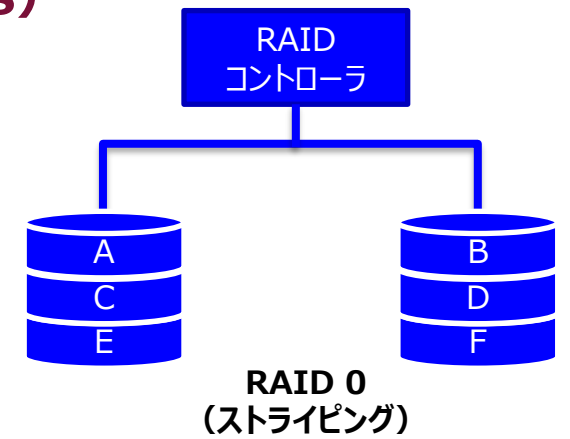
- RAIDとは、複数台のハードディスクを1台のハードディスクとして運用するための技術です。
- 記録するデータをどのようにハードディスクに書き込むのかによって物理的な冗長性を向上させる仕組みを持っています。

RAID 0

- ミラーリングやパリティのないストライピングで、フォールトトレランスはなく、リード・ライトの速度のみが速く、最低2台のディスクが必要になります。

RAID 1

- 複数ディスクに同一のデータを保管する構成であり、書き込み機能は両方のディスクに同時に書き込まれます。



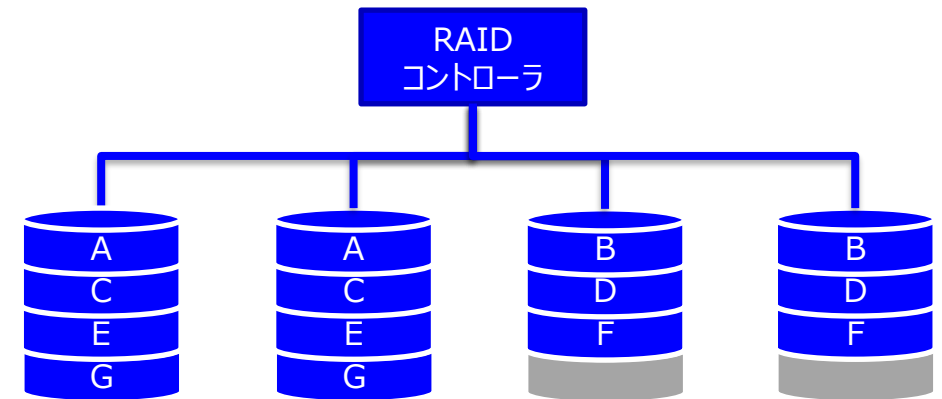
フォールトトレランス

メディア保護技術

● RAID (Redundant Array of Independent/Inexpensive Disks)

RAID 10

- RAID 0とRAID 1を組み合わせたRAID方式がRAID 10です。
- RAID 0のように別のディスクに同時に書き込みますが、RAID 1のように別のディスクは複数台で冗長化されています。



RAID 10 (ストライピング&ミラーリング)

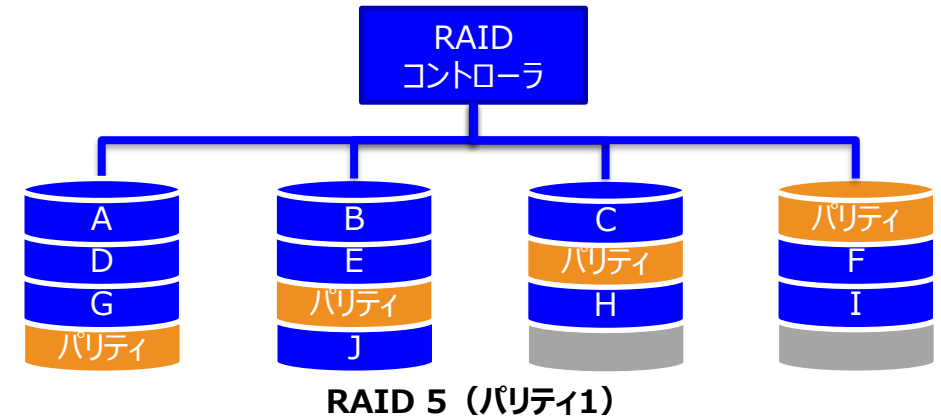
フォールトトレランス

メディア保護技術

● RAID (Redundant Array of Independent/Inexpensive Disks)

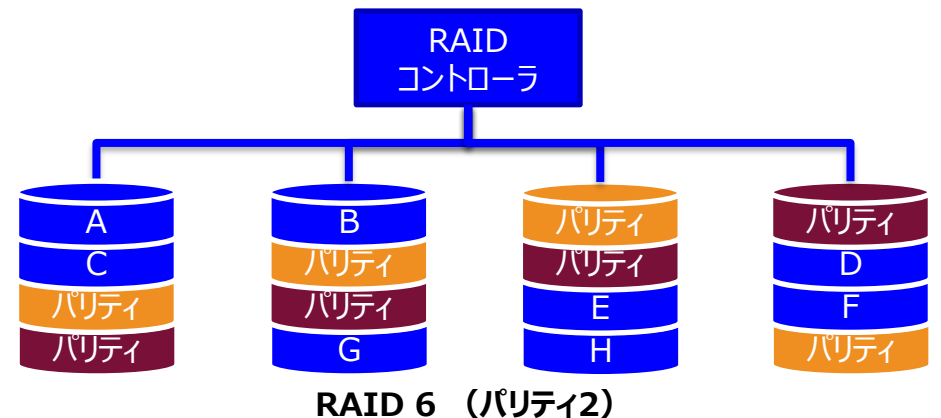
RAID 5

- 分散パリティによるブロックレベルのストライピングで、最低でも3台のディスクが必要です。
- パリティが使われあるディスク1台が落ちたとしても復旧できるようになっていますが、ディスク2台が破損した場合には復旧できなくなります。
- 速度と冗長性を兼ね備えています。



RAID 6

- RAID 5と同様に分散パリティによるブロックレベルのストライピングを利用します。ただし、パリティを二重で生成し、異なるディスクに記録します。
- 生成されるパリティが多いため、書き込みや必要な容量がRAID 5よりもかかりますが、RAID 5より耐障害性が高くなります。





事業継続計画 ／災害復旧計画

事業継続計画／災害復旧計画

事業継続計画（BCP）

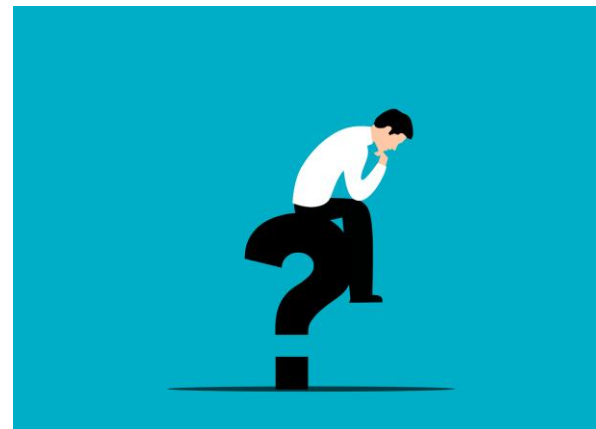
● BCPとDRP

- どのような組織でも災害に遭遇することがあるでしょう。どのようにして災害を回避し、どのようにして災害を軽減し、どのようにして災害が発生したときに回復するかが非常に重要です。このプロセスを怠ると、組織に深刻な影響を与えたり、事業を閉鎖しなければならないこともあります。
- ただし、こういった計画の数値的な根拠は経済的メリットによって決定づけられますが、災害の際に最も守らなければならないのは人命です。

難しいBCPは意味ある？

事業継続計画と聞くと、「どんな異常事態であっても信頼を損ねない論理的な計画」という意味合いに感じられるかもしれませんが、そうではありません。むしろ、そのような考え方が無理な計画を作り上げてしまい、非常に厄介で無意味なものと感じることもあるでしょう。

難しいことは考えず、“とりあえずデータを復旧するには？”という考え方が重要になります。もっと優しくいうと、“私物のスマホが壊れたら、何をすればいいんだっけ？”ぐらいのノリで、詳細を詰めていけばいいのです。



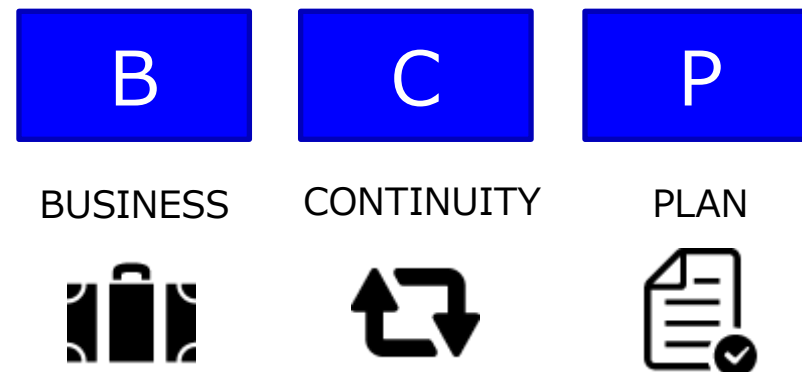
事業継続計画／災害復旧計画

事業継続計画（BCP）

● BCPとDRP

事業継続計画（ Business Continuity Plan ）

- ・ 事業継続計画とは、事業を継続するための長期的な戦略的事業計画、方針、手順です。
- ・ ITシステムだけでなく、影響を受ける可能性のある組織全体を対象とします。
- ・ さまざまな災害シナリオと復旧のためにプロセスで組織がとるべき指針を記載しています。
- ・ 事業継続計画は当然破壊的な事象が起こる前に作成され、継続的に改善されていくものです。



いざ！いざ！いざ！

引っ越しの時に物が捨てられないことはよくあります。会社も同じです。代替手段を用意しすぎるというのは、BCPではよくあるミスの一つです。代替手段があるということは、その分維持管理費もかかるということです。

事業継続計画／災害復旧計画

事業継続計画（BCP）

● BCPとDRP

災害復旧計画（ Disaster Recovery Plan ）

- ・ 災害復旧計画とは、事業継続計画の一つであり、災害時に重要なITシステムの復旧または継続を可能にするための短期的な計画です。
- ・ 事業継続計画は、事業を継続するための全体を対象としているため復旧だけではなく、その健全性の維持も含まれます。つまり、ITシステムの内容を主題としません。
- ・ 重要なビジネス機能を支えるITシステムに焦点を当て、災害後にそれらをどのように復旧させるかを考えます。

BCP

Business Continuity Plan

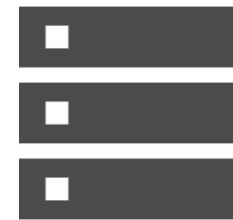
事業運営の継続性



DRP

Disaster Recovery Plan

ITインフラ復旧



事業継続計画／災害復旧計画

事業継続計画（BCP）

● 災害分類

自然

- ・ 地震、洪水、雪、竜巻、パンデミックなど、自然が原因で起こる災害があります。
- ・ 自然災害の脅威は地域によって異なります。地域リスク分析に結果から構造物の増強を行います。

人間

- ・ 非意図的とは、従業員がマルウェアを拡散させる場合です。
- ・ 意図的とは、テロリズム、ハクティビズム、フィッシングなどです。

環境

- ・ 環境に起因するものとしては、停電やスパイク、ハードウェアの故障、プロバイダーの問題などが考えられます。
- ・ 多くの場合軽微な影響しか与えませんが、潜在的なダメージを与える可能性がある問題がある場合は、軽減策を打ち出すべきです。

事業継続計画／災害復旧計画

事業継続計画（BCP）

● 災害の例

電力（環境）

- UPSと発電機の冗長性を確保し、長時間の停電の備えます。

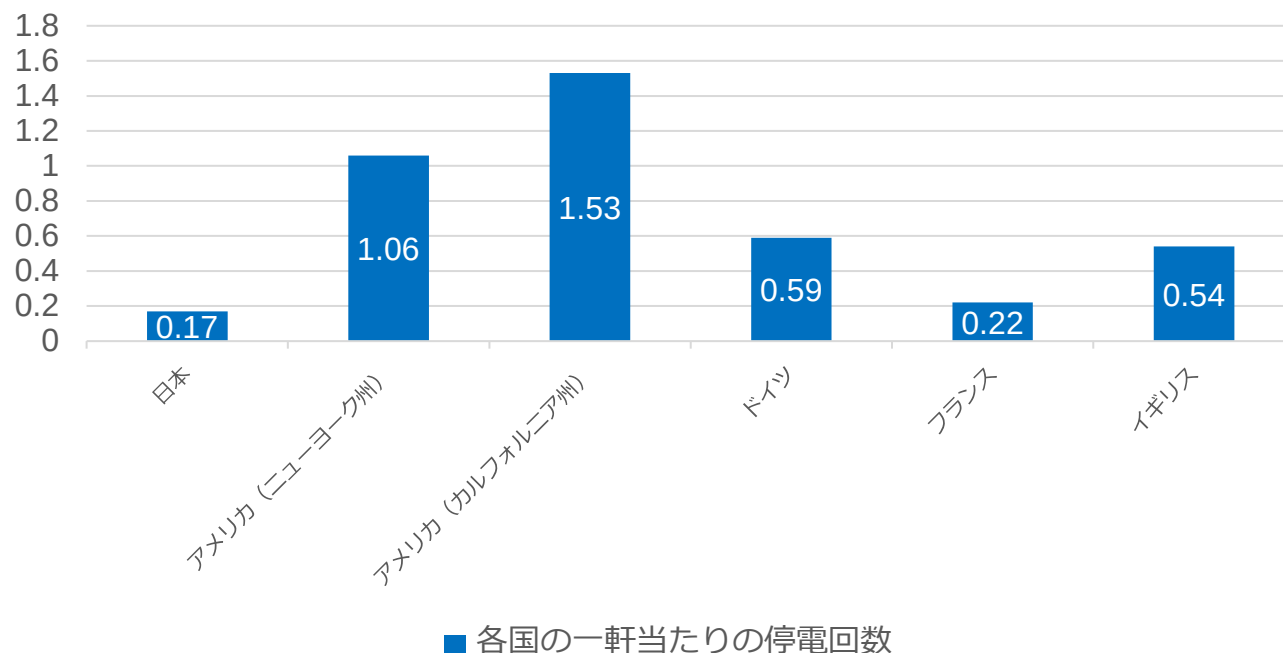
熱、圧力、湿度（環境）

- 湿度が低いと静電気が発生し、湿度が高いと金属（電子機器）が腐食します。

戦争、テロ、サボタージュ（人間）

- インターネットでは、国や宗教などの理由でハッキングを行うことが多くなっています。

各国の一軒当たりの停電回数



1. 日本・米国(ニューヨーク)は2020年度の事故停電・作業停電実績。米国(カリフォルニア)は2019年度の事故停電・作業停電実績。(出典) 電力広域的運営推進機関「電気の質に関する報告書(2020年度実績)」
2. ドイツ・フランス・イギリスは2016年の事故停電・作業停電実績。(出典) CEER「Benchmarking Report 6.1 on the Continuity of Electricity and Gas Supply」

事業継続計画／災害復旧計画

事業継続計画（BCP）

● 災害の例

金銭目的の攻撃者（人間）

- ・ 金銭的な動機を持った攻撃者が増えています。高度な技術を持っている場合とそうでない場合があります。
- ・ 低いスキルのものは、フィッシング攻撃、ソーシャルエンジニアリングなどを考えるでしょう。より高いスキルのものとしては、カード会員データの窃盗、個人情報の盗難、偽のアンチマルウェアツール、企業スパイなどを考えるでしょう。

パンデミック（自然）

- ・ インフルエンザやその他のウイルスなどの自然現象によって人員不足が引き起こされることもあります。
- ・ 人員の冗長性を確保し、人員が不足した場合に対処します。

地震とか言われても、イメージしにくいのですが...

自然災害系の障害については、発生する頻度が少ないため想定することが難しいでしょう。そういった場合には、自分らで考えるのではなく、専門家に頼ってもいいでしょう。日本では、防災訓練・防災教室も消防署に頼めば無料で指導してくれたり、指導を受けたうえで損害があった場合に補償を付ける場合もあります。（※詳細につきましては消防署にてご確認ください。）

事業継続計画／災害復旧計画

事業継続計画（BCP）

●事業継続計画の策定プロセス

①プロジェクトの開始

- ・ステークホルダーを特定し、Cレベル（CEOなど）の承認を得て正式に決定します。
- ・組織のリーダーであるシニアマネージャーは最終的に責任を負い、当然ながら優先順位、実行、計画そのものについて最終的な決定権を持っています。

②プロジェクトの範囲設定

- ・何をやろうとしているのかを明確にします。何を行い、何処まで保証するものなのかを明文化します。

③事業影響分析（BIA、Business Impact Analysis）

- ・重要なシステムやコンポーネントを特定し、優先順位をつけます。
- ・優先順位は、業務やシステムが停止した場合に事業に与える影響度から評価します。

①プロジェクトの開始

②プロジェクトの範囲設定

③事業影響分析

④予防的コントロールの識別

⑤復旧戦略

⑥プランの設計と開発

⑦模擬試験

⑧BCP/DRPのメンテナンス

事業継続計画／災害復旧計画

事業継続計画（BCP）

●事業継続計画の策定プロセス

④予防的コントロールの識別

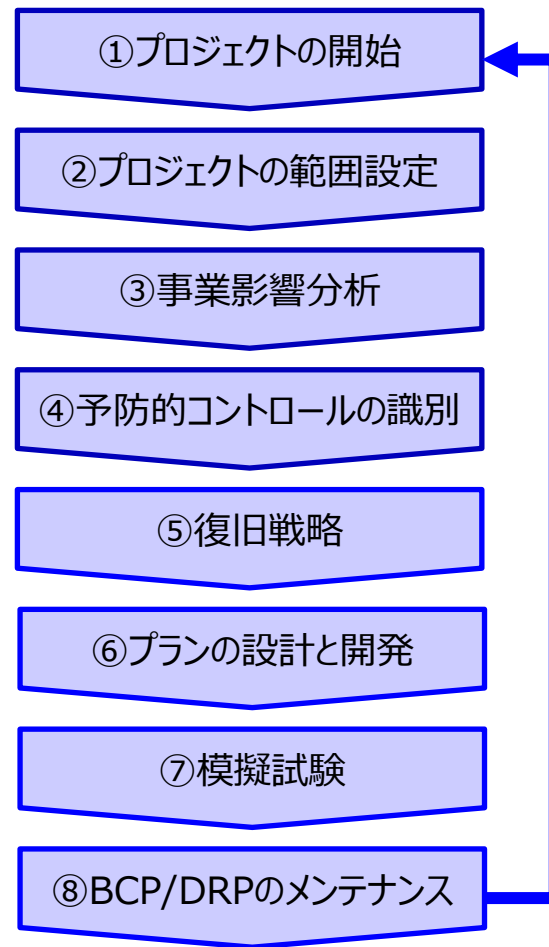
- 各システムやコンポーネントに対して、現在の予防的コントロールを特定します。
- 予防的コントロールが適用されていない箇所があるのか、適切な予防的なコントロールが行われているのかを把握するために整理します。

⑤復旧戦略

- DRサイトなどをどのようにして効率的に復旧させるのか戦略を検討します。
- 具体的な手順等については、次のフェーズで決定します。

⑥計画設計と開発

- 復旧のための具体的な計画、手順、ガイドラインなどを策定、復旧のためのツールを開発します。



事業継続計画／災害復旧計画

事業継続計画（BCP）

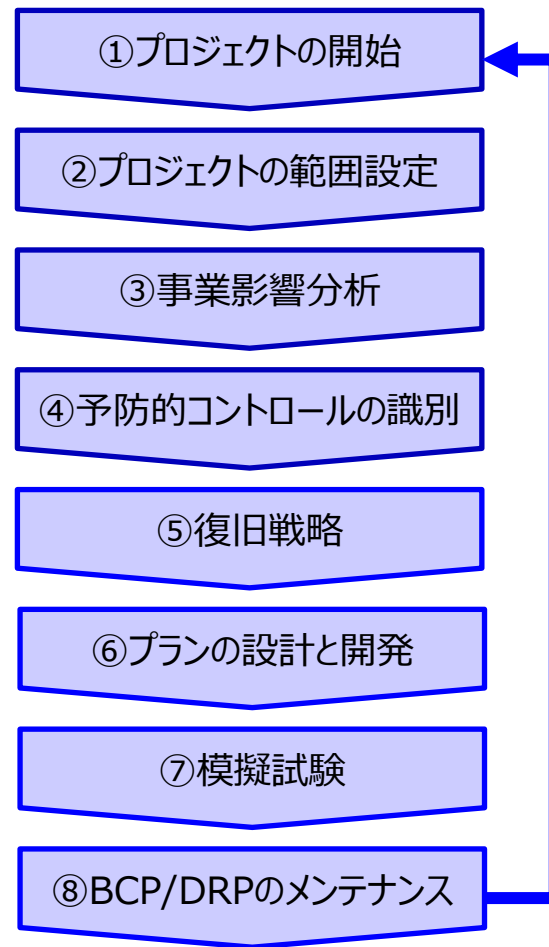
●事業継続計画の策定プロセス

⑦模擬試験

- ・計画を実際にテストすることで、現実的に機能するのを確認します。
- ・計画に基づいて行動できるようにスタッフを訓練します。

⑧BCP/DRPのメンテナンス

- ・トレーニングで得られた教訓を計画に落とし込みます。
- ・脅威の状況が変化する中で、BCPやDRPの改善や調整を続けなければなりません。



事業継続計画／災害復旧計画

事業継続計画（BCP）

● BCP/DRPのフレームワーク

NIST 800-34

- NIST 800-34では、連邦政府の情報システムの危機管理計画に関する指示、勧告、考慮事項を提供しています。
- 危機管理計画とは、障害発生後に情報システムのサービスを回復させるための暫定的な手段を指します。

ISO/IEC 27031

- ISO/IEC 27031では、社会的セキュリティ、事業継続マネジメントシステムのガイダンスとして、事業継続マネジメントに関するより実用的なアドバイスを提供しています。
- ISO 22301は、社会的セキュリティ、事業継続マネジメントシステム、組織の事業継続計画を管理するためのマネジメントシステムを規定しており、ISO 27031でサポートされています。

事業継続計画／災害復旧計画

事業継続計画（BCP）

● BCP/DRPのフレームワーク

BCI（Business Continuity Institute）

- BCI（Business Continuity Institute）とは、事業継続について活動している人たちが情報を互いに交換・提供するための組織です。
- 事業継続に関する独立した知識体系である「GPG（Good Practice Guidelines）」の6ステッププロセスを提示しています。

それって計画？それとも穴埋め？

事業継続計画にはいくつかのひな型がありますが、企業とはこうあるべきであるという教義的な解釈では、おそらくあなたはBCPに価値を見出せないでしょう。ただ項目を埋めた街頭アンケートのように、事業継続計画というシートの穴埋めをただで、事業を継続する効力など全くないケースもあります。

事業継続計画／災害復旧計画

事業継続計画（BCP）

● 復旧体制

レスキューチーム

- ・ レスキューチームは、従業員の避難、適切な担当者への通知（コールツリー）、感染したサーバーからのネットワークの引き抜きやシステムのシャットダウン、初期の被害状況の確認などを行います。

リカバリーチーム

- ・ リカバリーチームは、DRサイトを可能な限り迅速に立ち上げ、システムを再構築する責任を負います。
- ・ 最も重要なシステムを最初に稼働させることも目指します。

サルベージチーム

- ・ サルベージチームは、プライマリーサイトが破壊された場合は新施設にインフラ、スタッフ、オペレーションを戻すことを担当します。
- ・ 重要なシステムを戻す前に新しいサイトの準備が安定していることを確認したいため、重要度の低いシステムで一旦動作を確認することも判断します。

レスキューチーム



被害最小化

リカバリーチーム



早急に修復

サルベージチーム



元通り

事業継続計画／災害復旧計画

事業継続計画（BCP）

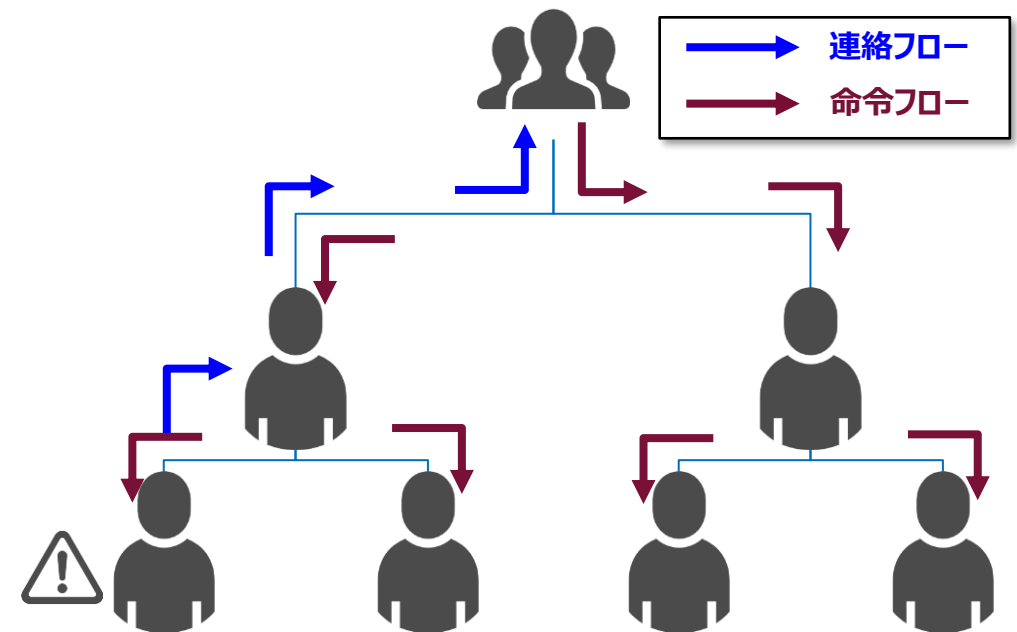
●復旧計画

危機連絡計画（CCP、Crisis Communications Plan）

- ・ 災害時の社内外のコミュニケーション方法の計画です。
- ・ 基本的に、インシデントを発見したスタッフはマネージャーやディレクターに連絡し、次にマネージャーやディレクターはCEOなどのシニアレベルの人に連絡します。CEOは残りのCレベルのリーダーを呼び、彼らは彼ら管轄のディレクターやマネージャーを呼び、マネージャーは管轄のスタッフを呼びます。

非常オペレーションセンター（EOC、Emergency Operations Center）

- ・ 緊急時に戦略的なレベルでの緊急管理または災害管理機能を担う一時的な指揮統制施設です。
- ・ 災害の影響が広範囲に及ぶ可能性があるため、地理的に遠隔に配置します。



一般的なコールツリー

事業継続計画／災害復旧計画

事業継続計画（BCP）

●復旧計画

運用継続計画（COOP、Continuity of Operations Plan）

- すべての危険を伴うアプローチからの緊急事態に対処するため、重要な機能が継続し、緊急時に人員とリソースが代替施設に移動されることを保証するポリシーとガイダンスを確立します。

サイバーインシデント対応・復旧（CIR、Cyber Incident Recovery）

- DDoS、ワーム、ウイルスなどのサイバーインシデントへの対応に特化した計画です。

人員緊急計画（OEP、Occupant Emergency Plan）

- 火災、ハリケーン、洪水、犯罪、テロなどの災害時に施設やスタッフ、環境をどのように保護する計画です。
- 安全と避難に焦点を当て、避難の方法、訓練の頻度、スタッフが受けるべきトレーニングについて詳しく説明しています。

事業継続計画／災害復旧計画

事業継続計画（BCP）

●復旧計画

ビジネス復旧計画（BRP、Business Recovery Plan）

- ・ 破壊的なイベントから回復した後、通常の業務を再開するために必要なステップを記載した計画です。
- ・ オペレーションを代替サイトから通常運用可能なサイトに戻すことなどが考えられます。

危機管理計画（CMP、Crisis Management Plan）

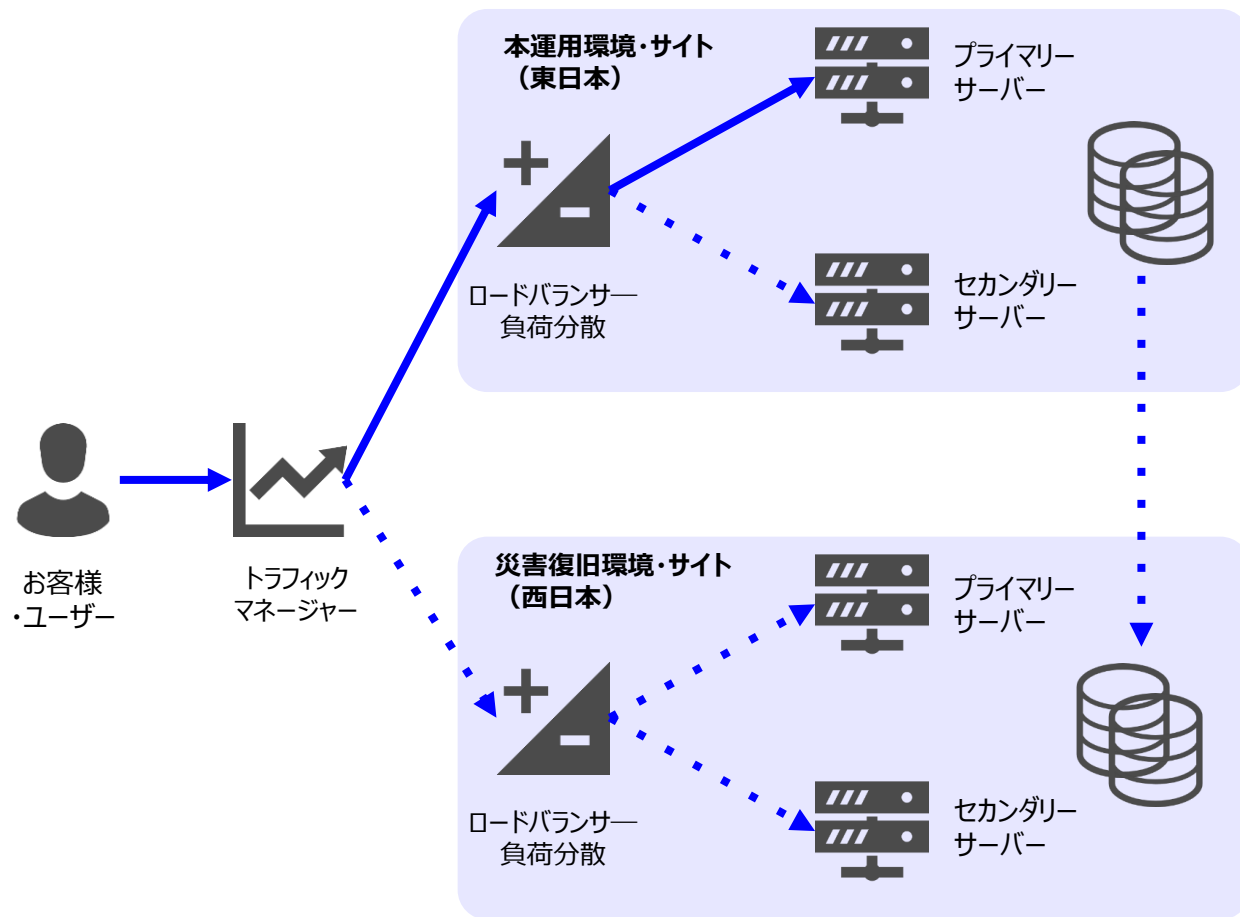
- ・ 緊急事態や破壊的な出来事が発生した場合に、組織の経営陣の間で効果的な調整を行うための計画です。
- ・ 災害時に人員の生命と安全および財産を直ちに保護するために、経営陣がどのような手順を踏むべきかを詳述します。

事業継続計画／災害復旧計画

災害復旧計画（DRP）

●DRサイト（Disaster Recovery Site）

- DRサイトとは、災害時における業務継続を確保するために、主にデータやシステムをバックアップし、災害発生時に迅速に復旧できるように設置された予備の施設です。
- DRサイトは、システム障害や自然災害、テロ行為などの緊急事態に対応するため、企業が通常業務を中断せずに運営できるよう支援します。



データセンターサイトは地理的に分離、それぞれプライマリ・セカンダリサーバに分離

事業継続計画／災害復旧計画

災害復旧計画（DRP）

●DR（Disaster Recovery）サイト

コールドサイト

- ハードウェアやバックアップはなく、復旧時にはシステムの取得、設定、アプリケーションのロードと設定が必要となります。

ウォームサイト

- リアルタイムデータではなく、以前に取得したバックアップから復元されます。
- トラフィックを手動でフェイルオーバーし、完全な切り替えと復元には4～24時間ほどかかります。

ホットサイト

- 重要なアプリケーションのみを収容し、低スペックのハードウェアを使用します。
- データはほぼリアルタイムでコピーされ、完全な切り替えには1時間以内で済みます。

	費用	待機 装備	データ 通信	復旧 時間	地理
コールドサイト	低	なし	なし	長	固定
ウォームサイト	中	一部	一部/ フル	中	固定
ホットサイト	中～ 高	フル	フル	短	固定
ミラーサイト	高	フル	フル	即時	固定
モバイルサイト	高	適宜	適宜	適宜	流動

事業継続計画／災害復旧計画

災害復旧計画（DRP）

●DR（Disaster Recovery）サイト

ミラーサイト

- 本運用環境と完全に同一構成のサイトで、本運用環境データのリアルタイムコピーを受け取ります。
- 最もコストのかかるDRサイトですが、エンドユーザーがフェールオーバーに気づくことはないでしょう。

モバイルサイト

- コンテナやトレーラーで移動できるデータセンターです。地理的なリスクを分散することができ、低性能でも継続したシステム稼働を目指します。

	費用	待機 装備	データ 通信	復旧 時間	地理
コールドサイト	低	なし	なし	長	固定
ウォームサイト	中	一部	一部/ フル	中	固定
ホットサイト	中～ 高	フル	フル	短	固定
ミラーサイト	高	フル	フル	即時	固定
モバイルサイト	高	適宜	適宜	適宜	流動

事業継続計画／災害復旧計画

災害復旧計画（DRP）

●データの転送

データベースシャドウイング（レプリケーション）

- データベースシャドウイングとは、データベースやファイルを別の場所に正確にリアルタイムでデータファイルをコピーすることです。
- 主系のデータベースダウンの際に、コピー先にデータベースに切り替えることで復旧できます。

リモートジャーナリング

- リモートジャーナリングとは、ファイルそのものではなくトランザクション・ログ・ファイルを送信することです。
- 処理中に障害が起きると、実行中のデータが更新後なのか更新前なのかを判断するのに役立ちます。

事業継続計画／災害復旧計画

災害対策トレーニング

●レビューと検証

チェックリスト（Read-Through）

- 管理者と職能部門が計画に目を通し、復旧プロセスに必要な構成要素のリストをチェックします。

ウォークスルー（Walk-Through、テーブルトップ、構造化ウォークスルー）

- 管理者と重要な担当者のグループが集まり、復旧プロセスについて話し合うことです。
- 復旧を妨げる可能性のある認識違いや、あるいは技術的な不正確さを明らかにすることができます。

ウォークスルードリル（Walk-Through Drill、シミュレーションテスト）

- チームが災害をシミュレートし、各チームがDRPを使って対応します。
- 実際に計画が機能するのか、計画通りに動けるのかを確認します。



各項目を満たせているか？



経験値から問題がないか？



実際に機能するか？

事業継続計画／災害復旧計画

災害対策トレーニング

●ウォークスルードリル

並列処理

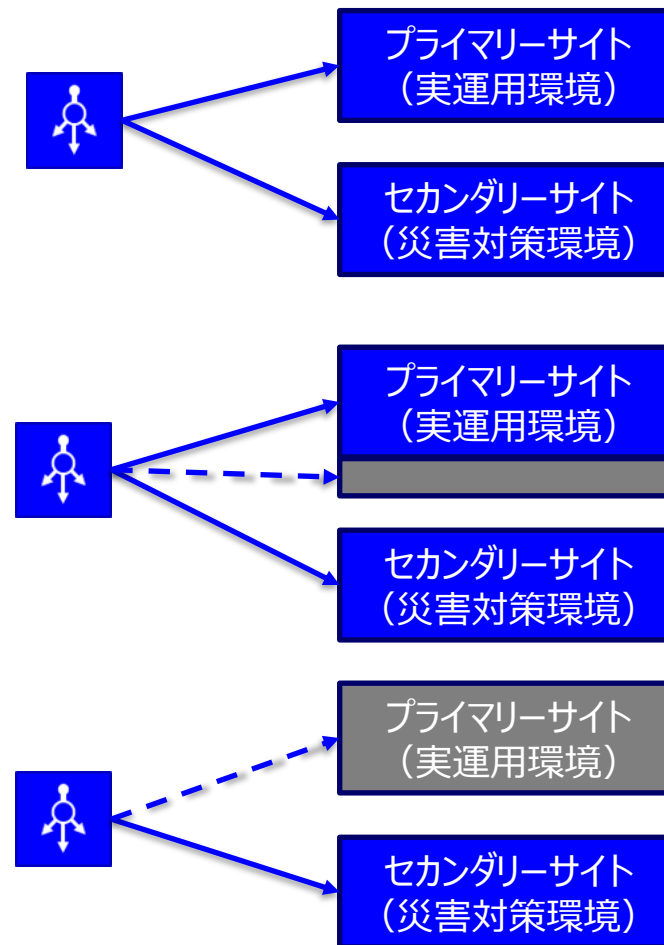
- ・ プライマリーサイトとセカンダリーサイトで同じシステムを立ち上げ、近日のバックアップを読み込んだ2つのシステムを比較します。
- ・ 中断するシステムがないため業務影響は出ませんが、障害時に自動的にセカンダリーシステムに切り替わる試験が残されます。

部分的な中断（Partial Interruption）

- ・ プライマリーサイトの部分的なアプリケーションを中断し、該当のセカンダリーサイトにフェイルオーバーします。
- ・ 部分的な中断をすることで業務影響を下げる可以做到。

完全な中断（Full Interruption）

- ・ プライマリーサイトのすべてのアプリケーションを中断し、セカンダリーサイトにフェイルオーバーします。
- ・ 完全な災害計画の検証になりますが、業務影響が出ます。





人員の安全

人員の安全

緊急事態管理

● 管理的なセキュリティ管理

管理的コントロール

- ・ ガイドライン、教育などの組織制度によるコントロールです。

強制的な休暇（ Mandatory vacations ）

- ・ 従業員に強制的な休暇期間を設けます。
- ・ 不在の間に従業員のアカウントはロックし、アカウントの監査が行われます。従業員が不正を行っている場合にも監査で発見されます。
- ・ 副次的に、従業員の仕事へのストレスを緩和する効果も考えられます。

名前	内容	例
技術的コントロール	情報システムによるコントロールです。	ソフトウェア、ハードウェア、アクセス制御設定
物理的コントロール	物体によるコントロールです。	ドア、フェンス
管理的コントロール	組織制度によるコントロールです。	ガイドライン、教育

その解決策は有効？

試験において、あるセキュリティ対策に関して、その有効性を問われることもあるでしょう。強制的な休暇などの組織変更を行う戦略は経験則から経済的なメリットがないと判断し、その有効性を排除してしまいがちです。しかしながら、その有効性も否定できるものではありません。
大企業のマネージャーになった気持ちで試験に挑むのがコツです。

人員の安全

緊急事態管理

● 個人に対するセキュリティ

- 個人に対して通常セキュリティで保護されたアクセス制御や内部統制から逸脱した活動を強制される可能性があります。

強迫システム（Duress system）

- 強迫警報/強迫システムは、人を追跡するために使用されるモバイルデバイスです。
- 人々の所在を追跡したり、もしくは精神的にも危険な状況にあるときの警告として使用できます。

旅行先でのネットワーク利用

- 旅行先での無料Wi-Fiは機密情報の漏洩のポイントです。いざという場合にインターネットの利用を提供してくれますが、端末内の情報を盗み取られる可能性があります。

人員の安全

セキュリティ意識

●セキュリティ強化の緊急対策

セキュリティ意識の重要性

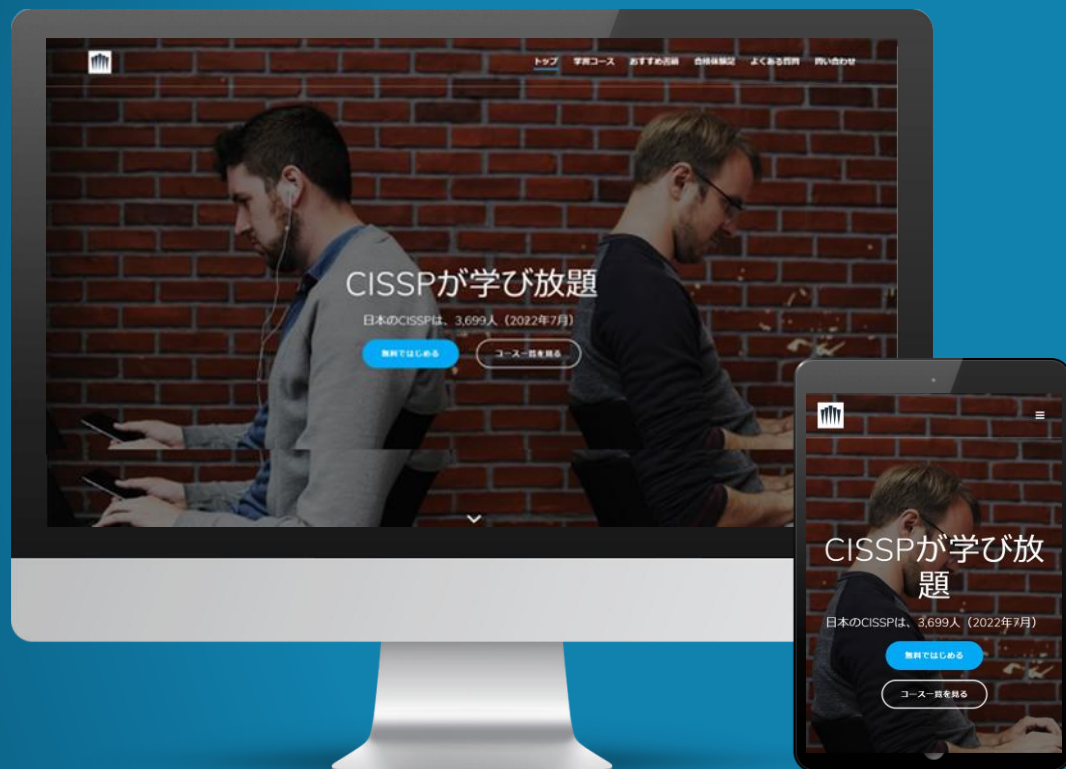
- 一般的なセキュリティ知識を身につけることで、システムに必要なセキュリティ機能を理解し、異常に気づきやすくなります。
- 例：多要素認証の疲労攻撃（攻撃者が繰り返し認証通知を送って誤認証させる）

ソーシャルメディアのリスク

- 従業員が無意識に業務関連や個人情報共有するリスクがあります。
- 偽情報や偽プロフィールの拡散による政治的操作、企業評判毀損、犯罪活動を助長します。
- 国家によるサイバー攻撃が誤情報流布を通じて個人に影響を与えている。
- 共有される情報が必ずしも正確とは限らないため、慎重な情報管理が求められます。



PIEDPINの紹介



なぜセキュリティを学ぶのか

セキュリティの最も大きな敵は、人はあらゆるものに慣れ、そのリスクを考えなくなる習性にあります。セキュリティの学びを通して得られる貴重なものは、あらゆる事象に対して好奇心を持つことであり、それは目まぐるしい現代を生きるのに大いに役立つでしょう。

- EASY DESIGN
- SUPER EFFICIENT
- EVERYWHERE

PIEDPINを選ぶ理由



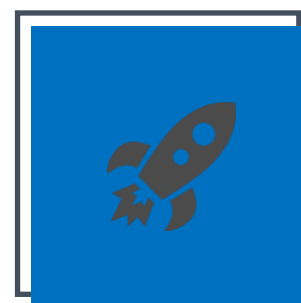
**EASY
DESIGN**

日本語で学べる



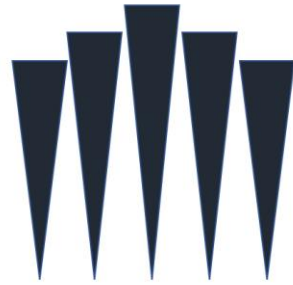
**SUPER
EFFICIENT**

わかりやすい説明



EVERYWHERE

どこからでも学べる環境



THANK YOU

CISSP for BEGINNER